

版本: 0.1

作者: <https://github.com/yurkingw/AISecGuide>

日期: 05/30/2026

企业级 AI 安全指引

1. 引言与目的

本指引为组织在企业环境中安全、可控、可审计地使用人工智能建立一套结构化、技术中立且可落地的方法。其适用于设计、开发、采购、集成、部署、运行、监控或退役 AI 使能系统的组织，包括基于大语言模型、检索增强生成、机器学习和代理式工作流的系统。本指引的主语不是抽象意义上的 AI，而是在真实运营、法律、商业和治理约束下，组织如何安全使用 AI。

尽管传统软件和信息系統已经拥有大量成熟标准，AI 系统仍带来了许多仅靠传统软件安全、隐私或运营风险方法无法完整覆盖的风险特征。AI 系统可能依赖会随时间变化、且有时会发生重大和意外变化的训练数据、微调数据、检索语料和实时上下文。尤其当其被部署在更大的社会技术工作流中时，其行为也可能难以预测、解释、复现或被穷尽测试。

AI 系统天然具有社会技术属性。其风险和收益不仅来自模型内部机制或代码质量，也来自技术设计、人类行为、组织流程、外部主体、市场激励以及系统所处社会环境之间的相互作用。因此，同一个模型会因使用者是谁、具有什么权限、哪些下游系统信任其输出，以及外围制度控制如何设计，而呈现出显著不同的风险。

AI 风险、AI safety、AI security 与网络安全风险彼此相关，但并不相同。AI 风险是最宽泛的类别，涵盖运营、法律、伦理、市场、安全、系统性和治理问题。AI safety 更关注防止有害行为、功能失效和不安全后果，尤其是在模型行为可能造成现实世界损害时。AI security 更关注保护 AI 系统本身、围绕 AI 的系统以及依赖 AI 的组织，防止其被滥用、操纵、攻破、越权泄露或失去控制。网络安全风险仍然重要，因为 AI 系统建立在软件、基础设施、身份体系、数据流和供应链之上，这些部分即使模型本身不是故障中心，也依然会受到传统攻击。

本指引并不试图替代行业监管、系统安全工程、隐私法、模型治理政策或软件安全标准，而是提供一套统一的企业控制语言，使董事会、高管、安全负责人、风险责任人、工程团队和审计团队能够以一致方式讨论 AI 安全。它旨在支持内部制度制定、用例准入评审、架构审批、采购尽调、独立保证、事件响应和控制测试。

本指引所提供的控制措施并非在所有情况下均构成强制要求；任何控制措施的实施均宜基于已批准的风险评估结果确定。在本文件中，**应 / shall** 有两层含义。第一，它表示对纳入范围的 AI 用例普遍适用的治理要求，例如责任归属、用例分类、影响分级、适用性判定、例外处理和证据留存。第二，它表示一旦组织判定某项控制对特定用例适用，该控制即构成基线要求。如某项控制不被采用，宜有文档化的风险评估依据，并在相关情况下配套例外处理记录。

本指引面向大型企业编写，并叠加适用于大型金融机构的强化要求。基础要求被设计为能够适用于外部托管 API、自托管模型、传统机器学习系统、基于检索的应用、代理式系统以及混合架构。金融行业强化部分则针对客户影响、监管审查、市场敏感性、集中度风险和运营依赖共同抬高高风险的场景提出更高要求。

1.1 值得信赖的 AI 特征

本指引采纳这样的观点：值得信赖的 AI 应当在其影响和使用场景相称的程度上体现以下特征：**有效且可靠**、**安全(Safe)**、**安全(Secure)**且具韧性、**可问责且透明**、**可解释且可理解**、**隐私增强**，以及**公平且有害偏差得到管理**。这些特征不应被当作抽象口号，而应被转化为设计要求、审批标准、运行控制、保证证据和变更阈值。

有效且可靠的性能是其他特征的必要基础，但单独拥有它并不足够。一个系统即便在基准任务上表现准确，也仍可能在真实部署中不安全、在攻击下不具韧性、在决策影响上不透明，或在敏感人工工作流中造成损害。

1.2 非目标

本指引不提供产品推荐，不提供法律意见，也不对特定法域进行逐条监管解释。它不规定单一的 AI 系统架构，不假设任何单一厂商、模型家族或安全工具可以消除 AI 风险，也不将提示过滤、模型对齐或内容审核视为组织控制、下游授权或运行监督的充分替代。

1.3 预期成果

实施本指引后，组织宜能够一致地对 AI 用例进行分类，清晰界定责任归属，保护敏感数据和系统行为，约束模型与代理的行动，验证高风险输出，监测有害变化，并证明 AI 相关风险决策是有意识的、基于证据的且可复核的。

1.4 规范解释与适用性

在实际使用时，组织宜将本指引中的要求理解三类。第一，**普遍治理要求** 适用于所有纳入范围的 AI 用例，包括台账、责任归属、分类、影响分级、适用性判定、例外处理和证据留存。第二，**条件触发型控制要求** 会在用例的架构形态、数据敏感度、权限等级、运行场景或行业强化层触发时适用。第三，**强化要求** 适用于高影响、关键影响、具有重大后果，或因法律、审慎、客户或市场敏感性而需要更高控制强度的用例。

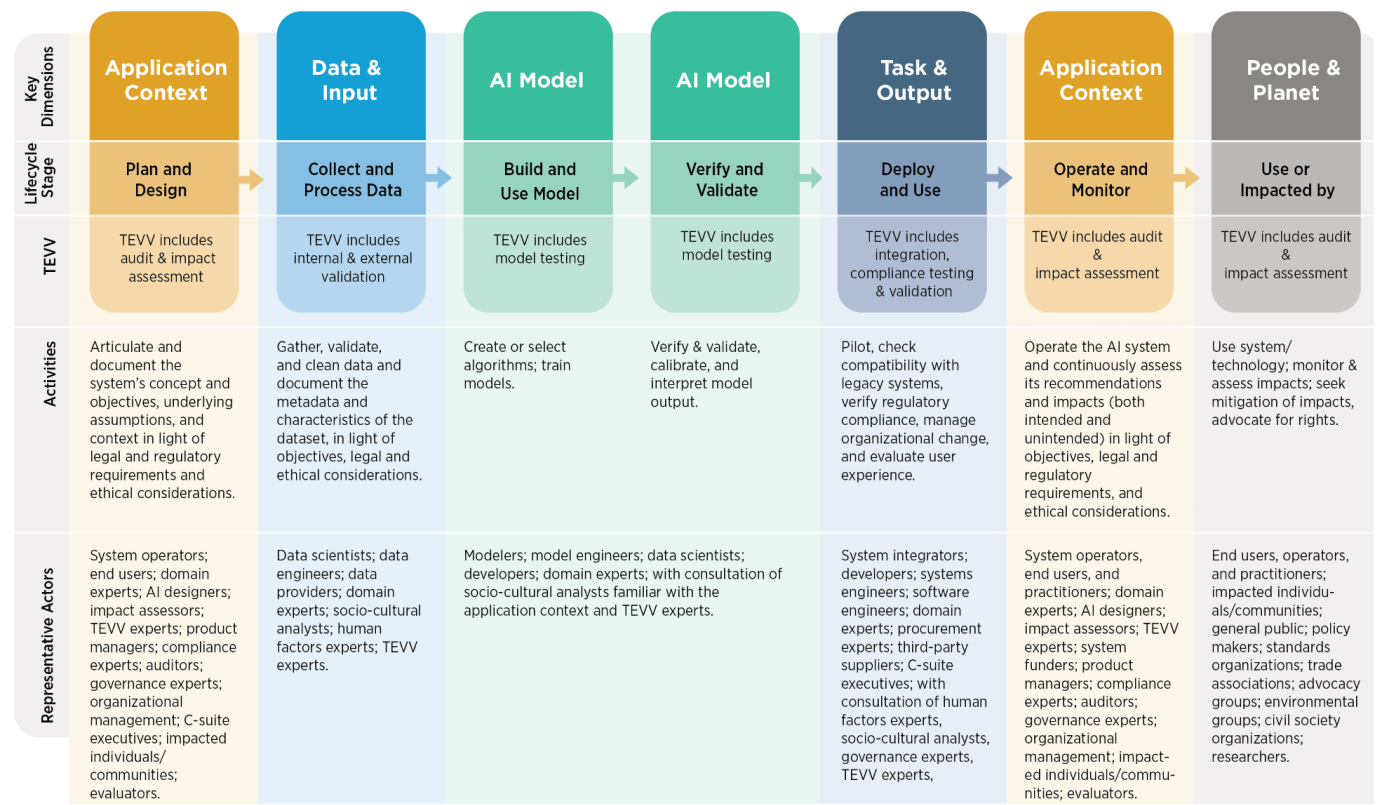
因此，组织应避免两种相反错误：一是把所有 **shall** 语句都机械地理解为对所有用例自动强制适用；二是把领域章节中的 **shall** 语句当作无需给出适用性判断记录的可选建议。预期结果应当是：适用逻辑明确、例外逻辑明确、两者均有可审计证据。

2. 范围框架与分类

组织应使用一组相互补充的视角来定义 AI 安全范围，而不是仅以模型为中心的单一视角。本章的目的，是防止只关注模型本身而忽略生命周期阶段、数据来源、验证工作、周边系统、人工流程、受影响人群以及网络安全交互关系的狭义或误导性范围设定。

本指引采用四类互补的范围界定视角。第一，AI 应被视为一个跨越应用场景、数据、模型开发与使用、验证与确认、部署、运营，以及使用者或受影响群体的社会技术系统。第二，AI 安全应通过 AI 与网络安全的相互作用来观察，包括保护 AI 系统本身、使用 AI 支持防御，以及构建对 AI 使能威胁的韧性。第三，AI 风险还应通过对手生命周期视角来观察，以避免针对模型、数据、代理、工具和周边系统的蓄意攻击路径被掩盖在笼统控制语言之下。第四，常见的 LLM 与代理式失效模式还应通过防守方优先级视角来观察，以便对设计、运行时和响应控制进行务实排序。

2.1 AI 生命周期与社会技术系统视角



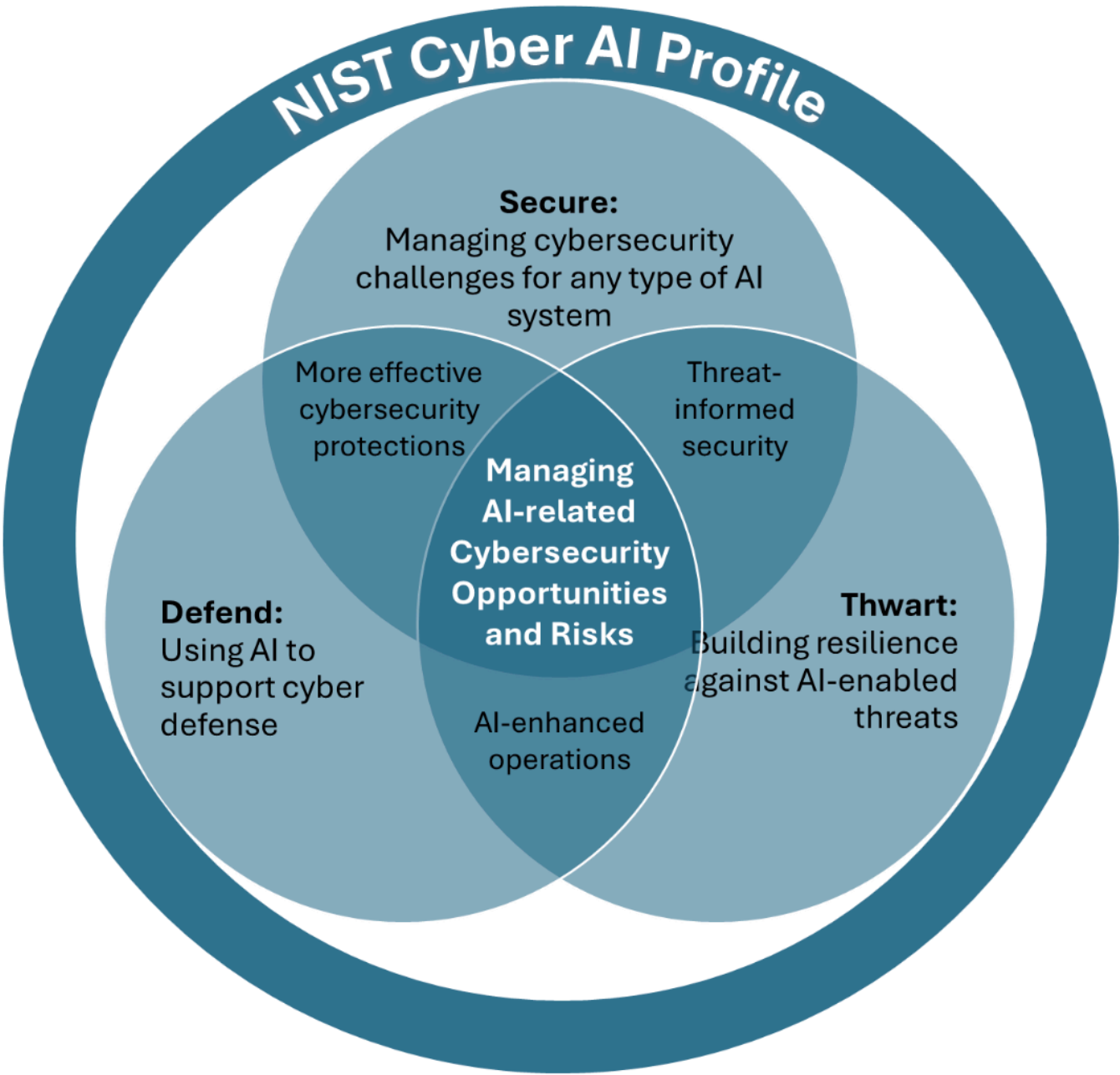
AI 生命周期视角强调，AI 安全范围横跨 **Application Context**、**Data and Input**、**AI Model**、**Task and Output** 以及 **People and Planet** 等关键维度，也横跨规划、数据处理、模型构建、验证与确认、部署、运行和现实影响等生命周期阶段。它同时明确指出，TEVV、运营活动以及代表性参与方贯穿整条链路，而不是仅存在于某一个孤立的工程步骤中。

这一视角不应被简化为传统软件开发生命周期。在企业 AI 系统中，行为不仅由代码决定，也会受到训练与参考数据、提示词、检索上下文、记忆状态、工具配置、用户交互和运行环境的共同影响。因此，即使复用同一个底层模型，只要用例或部署上下文不同，也可能形成实质不同的风险轮廓。

这一视角之所以重要，是因为许多 AI 失效并不发生在模型本身，而是源于问题定义薄弱、数据采集不当、验证不足、部署假设不安全、监控缺失，或源于下游用户和受影响群体承受的损害。

它也反映了 AI 的社会技术属性。控制失效往往并非来自单一技术缺陷，而是来自模型输出、人工判断、流程设计、委托权限和业务激励之间的相互作用。因此，AI 安全评审应同时考虑人员如何理解输出、何时容易对其过度信任、审批如何被授予，以及运行反馈如何随时间改变系统行为。

2.2 网络安全与 AI 交互视角



网络安全与 AI 交互视角强调，AI 安全不应被理解为仅仅保护模型不受攻击。它至少包括 **Secure**，即管理 AI 系统自身的网络安全挑战；**Defend**，即使用 AI 提升网络防御能力；以及 **Thwart**，即建立对 AI 使能威胁的韧性。这三者的交叉区域则体现了 AI 相关网络安全机会与风险，例如更有效的保护措施、受威胁情报驱动的安全，以及 AI 增强型安全运营。

这一视角之所以重要，是因为 AI 既是需要被保护的资产，也是能力放大器。组织既要保护 AI 系统及其周边技术栈不被攻破，也要认识到 AI 可能提升针对其他系统、用户和业务流程的攻击速度、规模、适应性和欺骗质量。

它也进一步说明，相关攻击面远不止模型本身。企业 AI 安全还必须覆盖身份、数据流、提示词、检索路径、工具、连接器、执行环境、外部服务以及输出消费路径。若将模型视为唯一控制焦点，周边系统中的实质暴露面就会被遗漏。

这一视角对企业尤其重要，因为 AI 同时可能成为攻击面、防御能力，以及放大对手速度、规模和欺骗质量的倍增器。

就本指引而言，Secure 主要体现为设计期和架构期控制，Defend 主要体现为使用 AI 强化安全职能的运营能力，Thwart 主要体现为针对 AI 使能滥用的运行时遏制、检测、响应与恢复。第 3-9 章宜结合阅读，以共同体现这三类安全目标在各控制域中的展开，其中第 5-9 章更偏重技术和运行控制。

2.3 MITRE ATLAS 对手生命周期视角

MITRE ATLAS 视角补充了一个“对手行为链”和“对手生命周期”视角，用于与上述 AI 生命周期视角以及网络安全与 AI 交互视角形成互补。对于企业 AI 安全而言，这一点很重要，因为许多失效不仅是工程缺陷或治理缺口，也可能是针对模型、数据、工具、代理及周边业务流程实施的侦察、访问、操纵、规避与影响链。

当前官方 MITRE ATLAS 矩阵包含 16 个 tactic、170 条 technique 和 35 条 mitigation。组织宜将下列 tactic 视为企业范围界定、威胁建模、红队测试、控制验证和事件响应设计中的威胁驱动叠加层。

同一条 technique 可能映射到多个 tactic。因此，组织宜将 tactic 视角理解为一种对手生命周期组织方式，而不是互斥的唯一分类法。

战术编号	战术名称	企业安全含义
AML.TA0002	Reconnaissance	与 AI 系统相关的对手情报收集与目标理解。
AML.TA0003	Resource Development	为后续 AI 攻击行动准备能力、基础设施、工具和工件。
AML.TA0004	Initial Access	获得对 AI 环境、工作流或相连业务流程的初始立足点。
AML.TA0000	AI Model Access	获得对模型、模型接口或模型邻接交互路径的访问。
AML.TA0005	Execution	执行可驱动 AI 系统行为的代码、提示、输入或操纵。
AML.TA0006	Persistence	在 AI 资产、状态或工作流上维持持续存在或持久影响。
AML.TA0012	Privilege Escalation	在 AI 技术栈或关联系统中扩大权限或控制范围。
AML.TA0007	Defense Evasion	规避围绕 AI 系统的保护措施、监控、策略检查或检测逻辑。
AML.TA0013	Credential Access	获取会暴露 AI 系统或邻接环境的凭据、密钥或令牌。
AML.TA0008	Discovery	了解运行时状态、模型行为、策略、资产和可达路径。
AML.TA0015	Lateral Movement	在相互连接的 AI 或企业组件之间横向移动。
AML.TA0009	Collection	从 AI 系统或邻接流程中收集有价值的数据、工件或输出。
AML.TA0001	AI Attack Staging	专门为利用 AI 而准备或塑造攻击输入、工件或攻击序列。
AML.TA0014	Command and Control	在 AI 使能的入侵链中维持远程影响、控制或信号传递。
AML.TA0010	Exfiltration	将敏感输出、模型、数据或其他高价值工件移出环境。
AML.TA0011	Impact	通过 AI 受损或滥用造成运营、安全、财务或信任损害。

这一生命周期视角并不取代本指引中的抽象风险模式库，而是提供了一个更具体的对手视角，帮助组织把通用风险陈述转化为攻击假设、检测思路、测试场景和证据要求。附录 E 提供的是优先技术与缓解措施参考，而非完整 ATLAS 数据集复写。

2.4 OWASP LLM 与代理式防御视角

OWASP Top 10 for LLM Applications 2025 和 OWASP Top 10 for Agentic Applications 2026 提供了一个偏向构建者与防守者的观察视角，用于补充上述 AI 生命周期、网络安全与 AI 交互以及对手生命周期视角。与广义企业分类法或攻击技术矩阵不同，这两份 OWASP 文档优先梳理的是应用团队、平台团队和防守方在真实部署中反复遇到、最具操作意义的失效模式，并为每一项配套预防与缓解指导。

对本指引而言，这两份 OWASP 文档宜被用作“防守优先级叠加层”。它们帮助组织把抽象风险模式转化为可执行的 secure-by-design、secure-by-default 和 secure-in-operation 期望，尤其适合指导运行时护栏、审批路径、工具权限、可观测性、测试用例以及事件响应覆盖范围的设计。

LLM Top 10 重点强调围绕提示、数据暴露、检索、输出、供应链和资源消耗的应用层控制：

OWASP LLM 条目	防御重点	企业控制含义
LLM01:2025 Prompt Injection	Prompt and context integrity	将所有外部与检索内容视为不可信；分离指令与数据；在执行高风险工具或工作流效果前实施校验。
LLM02:2025 Sensitive Information Disclosure	Confidentiality and exposure control	最小化提示、上下文、记忆和输出中的敏感数据；实施检索范围控制、密钥卫生和输出过滤。
LLM03:2025 Supply Chain	Upstream dependency assurance	评估提供方、模型、插件、数据源和库的来源、完整性、变更透明度和退出风险。
LLM04:2025 Data and Model Poisoning	Integrity of training, tuning, and grounding inputs	治理数据血缘、清洗、验证、回滚和重新评估，防止被投毒的工件悄然劣化系统行为。
LLM05:2025 Improper Output Handling	Output trust boundary	在通过结构、策略、业务规则和执行权限校验前，将模型输出视为不可信。
LLM06:2025 Excessive Agency	Bounded autonomy	实施最小权限、最小代理和人工审批，防止模型直接发起不安全动作。
LLM07:2025 System Prompt Leakage	Prompt confidentiality and design realism	不要把提示词当作主要秘密存储；隔离真正敏感信息，并假设提示内容最终可能暴露。
LLM08:2025 Vector and Embedding Weaknesses	Retrieval-path security	通过租户隔离、索引完整性、分块来源、查询控制和检索校验保护 RAG 路径。
LLM09:2025 Misinformation	Harmful inaccuracy control	对高影响输出采用 grounding、来源标注、置信度处理、人工复核和下游护栏。
LLM10:2025 Unbounded Consumption	Resource, cost, and abuse governance	采用配额、限速、负载整形、异常检测和成本感知控制，防止资源耗尽和财务滥用。

Agentic Top 10 将这一防御视角扩展到能够进行多步规划、调用工具、存储记忆、与其他代理通信并代表用户行动的系统。其指导尤其强调 least-agency、强可观测性、非人身份治理，以及对自主失效传播的约束与遏制。

OWASP 代理式条目	防御重点	企业控制含义
ASI01 Agent Goal Hijack	Goal integrity	约束目标的设定、继承和变更方式；对高影响目标偏移要求可信策略仲裁和升级。
ASI02 Tool Misuse and Exploitation	Tool invocation safety	对工具进行 allowlist 管理、参数校验、副作用约束，并将工具使用绑定到明确授权和上下文检查。
ASI03 Identity and Privilege Abuse	Non-human identity governance	将代理身份、令牌、会话和委托权限视为一等安全主体，实施最小权限和可撤销控制。
ASI04 Agentic Supply Chain Vulnerabilities	Trust in agent dependencies	将提示、模型、工作流、MCP 服务、工具定义、连接器和编排依赖视为供应链进行治理，而不只是静态代码。
ASI05 Unexpected Code Execution (RCE)	Execution isolation	对代码执行进行沙箱隔离、移除环境默认信任、限制文件/系统/网络访问，并将执行权限置于模型隐式控制之外。
ASI06 Memory & Context Poisoning	Durable context integrity	治理记忆写入、信任分层、保留策略、来源和长期上下文审查，防止被污染状态静默影响后续行动。
ASI07 Insecure Inter-Agent Communication	Agent-to-agent trust boundary	对通道进行认证，校验消息结构和来源，防止代理隐式信任其他代理的指令或工件。
ASI08 Cascading Failures	Blast-radius containment	对代理和工作流进行隔离，设置熔断、限速、回滚路径和安全降级，阻止局部失效扩散为系统级故障。
ASI09 Human-Agent Trust Exploitation	Trust calibration and approval hygiene	设计界面和流程，使用户在批准或依赖代理前，能够理解其已知信息、假设前提和拟执行动作。
ASI10 Rogue Agents	Autonomous deviation detection and containment	监控代理行为偏离情况，配置 kill switch 和权限撤销路径，并确保自主循环可被中断和调查。

这一 OWASP 防御视角既不替代 ATLAS 对手生命周期视角，也不替代抽象风险模式库。它回答的是另一个问题：在已经知道常见 LLM 和 Agentic 失效模式的前提下，团队应优先建设、限制、监控、审批和测试什么。

2.5 企业范围与控制边界落地层

组织宜通过一个可操作的企业范围与控制边界落地层，将上述四类视角真正落地。在本指引中，这一落地层被表达为五个范围层次，用于把广义的社会技术视角、具备网络安全意识的 AI 认知、对手视角以及防守者视角转化为具体的控制边界。

这一落地层并不是第五套独立框架，而是一个转换层，用于将前述四类视角转化为企业治理、架构、运营和保证决策。它的目的在于避免组织仅将某个 AI 能力视为模型、应用或采购对象之一来审查，因为在实际中，它往往同时跨越多类责任边界和控制边界。

之所以需要这一叠加层，是因为单个 AI 用例通常会同时跨越生命周期边界、对手暴露边界、应用或代理失效边界以及组织问责边界。若这些边界未被明确表达，控制责任往往只会按组件归属来分配，从而在审批、监控、测试或事件响应上留下实质缺口。

下列五个范围层次宜被用作一种操作性的范围界定方法。组织宜用其确定谁承担责任、哪些控制适用、哪些用例需要升级审批，以及在哪些场景下需要更强的可观测性、更严格的运行时授权或金融行业强化要求。边界划定错误本身也应被视为 AI 安全风险来源。

2.5.1 组织与责任层

组织应识别负责 AI 用例决策、审批、建设、运行、监控和退役的各类主体。至少应覆盖高管问责、业务所有权、技术所有权、安全所有权、风险承受授权、采购授权、法务或合规审查，以及独立保证职能。即使同一团队承担多个角色，组织也应定义其角色边界和升级路径。

2.5.2 生命周期层

范围应覆盖采购或引入、设计、开发、测试、部署、运行、变更管理、事件处置、停用和退役。组织不应将审查局限于部署时控制，因为许多 AI 安全失效源于不安全采购、薄弱的数据处理、缺乏文档的变更，或部署后的非受控学习与配置漂移。

2.5.3 系统栈层

范围应包括运行环境、身份体系、平台服务、模型、数据流水线、训练与微调资产、知识库、向量库、提示与策略、工具与插件、代理编排、用户界面、外部 API，以及日志与监控系统。对于自建 AI 环境，范围还应显式覆盖 GPU 集群、高速网络、DPU 或 SmartNIC、存储网络、调度器与集群控制平面，以及带外管理路径。组织不得将某一层的安全假设简单外推为所有其他层都同样成立。

2.5.4 使用模式层

组织应区分信息辅助、内容生成、分析支持、业务决策支持、客户交互、工作流自动化，以及半自主或自主行动。即便同一模型、同一数据被复用于不同场景，其风险也会因为只是起草文本、影响决策，还是能直接触发下游行动而发生实质变化。

2.5.5 影响等级层

组织应按其对机密性、完整性、可用性、法律与监管暴露、客户权益和结果、运营连续性、财务损失、市场影响以及声誉稳定性的潜在影响对 AI 用例进行分级。高影响和关键影响用例应受到更强的准入控制、更高的证据要求、更严格的变更管理以及更保守的运行时授权约束。

2.6 AI 风险与传统软件风险的差异

与传统软件相比，AI 系统引入了新的或被显著放大的风险，组织在范围界定、评审和控制设计时应予以考虑。这些差异并不意味着传统网络安全、隐私、软件保证或运营韧性实践失去意义；相反，它们意味着这些实践必须叠加 AI 特有的分析、证据和控制。

组织宜至少考虑以下 AI 特有或被 AI 放大的差异：

下表刻意保持简洁。其目的不是重复全部来源材料，而是说明为何仅依赖熟悉的软件控制并不足够，以及每一类 AI 特有差异会带来什么额外控制含义。

AI 特有风险差异	描述	主要控制含义
数据与场景不匹配	用于构建或调优 AI 系统的数据，可能并不匹配系统真实投入使用时的场景条件；而可靠的 ground truth 也可能不完整、存在争议或根本不可得。	针对具体用例开展数据审查、场景化验证、偏差审查，并对高影响用途实施更强准入控制。
大规模数据依赖	AI 系统不仅在训练和评估时依赖庞大、复杂且持续变化的数据，在很多情况下也依赖运行时检索和 grounding 数据。	强化数据血缘、来源、最小化、分段隔离和检索治理。
训练敏感性与行为漂移	微调数据、提示词、检索设置或系统配置中的细小变化，只要理解不足，就可能造成系统行为的实质变化。	将调优、提示和检索变更视为重大变更，纳入变更控制和重新验证。
上下文脱钩与陈旧化	曾经适用的数据或评估集，可能会逐渐过时、脱离其原始含义，或不再反映当前生产环境。	要求开展新鲜度审查、重新校准、数据集退役标准管理以及面向部署场景的重新评估。
规模、不透明性与涌现复杂性	与传统软件中的确定性代码路径相比，大模型的行为更难被完整解释、稳定复现或事先预测。	采用分层控制、边界化授权、运行时监控和基于证据的保证，而不是假设系统可被完全预测。
预训练模型不确定性	复用预训练模型可以提升效率和性能，但也会带来来源、偏差、可复现性、科学有效性，以及是否超出原始适用场景使用等方面的不确定性。	在重大部署前强化供应商尽调、来源审查、用途约束和独立验证。
隐私放大效应	即使原始记录未被直接暴露，AI 系统也可能通过推断、重建、组合或转述敏感信息而造成隐私损害。	实施数据最小化、目的限制、输出控制、记忆控制和隐私增强设计。
更频繁的重新验证需求	与传统软件相比，AI 行为更容易随时间变化，因为数据、概念、供应商、检索源和运行场景都会发生变化。	采用事件驱动的重新验证、漂移监控、回滚准备和明确的复审触发条件。
测试与文档成熟度不足	对于许多 AI 系统，尤其是复杂系统和生成式系统，其测试方法、文档标准和证据要求仍不如传统软件成熟。	通过场景测试、对抗性评估、安全论证、结构化文档和证据留存进行补偿。
攻击面扩张	AI 系统会引入或放大一些旧有软件或网络安全框架未充分覆盖的风险，包括提示注入、模型提取、规避攻击、滥用以及对关联系统的 AI 使能性滥用。	扩展威胁建模、滥用场景测试、边界校验以及下游授权控制。
第三方与超原始用途依赖	组织可能依赖外部模型或系统，而这些模型或系统的训练、调优或运行并不处于自身控制环境内，且原始用途也可能不同于当前用例。	实施第三方风险管理、超原始用途审查、退出规划以及合同透明度要求。
环境与副作用不确定性	AI 系统可能带来运营、环境或系统性副作用，例如高算力消耗或难以预判的下游后果，而这些问题仅靠狭义性能指标往往看不出来。	纳入更广泛的影响评审、运行边界限制、韧性规划和非性能类风险评估。

因此，组织宜将 AI 安全和 AI 风险管理视为企业风险管理的扩展，同时在适用时结合使用既有的安全与隐私框架，例如 NIST Cybersecurity Framework、NIST Privacy Framework、NIST Risk Management Framework 和 Secure Software Development Framework。

2.7 基础风险模式库

本指引以抽象风险模式而非漏洞清单作为主要分类方法。风险模式是指在不同模型、架构和业务流程中重复出现的受损、失控或有害后果形成方式。

组织至少应使用以下风险模式库：

1. Trust Boundary Violation / 信任边界穿透
2. Sensitive Information Exposure / 敏感信息暴露
3. Supply Chain and Provenance Opacity / 供应链与来源不透明
4. Manipulation of Model or Context / 模型或上下文被操纵
5. Privilege Amplification and Unauthorized Action / 权限放大与越权行动
6. Output-Driven Downstream Harm / 输出驱动的下游损害
7. Misuse, Fraud, and Deceptive Operation / 滥用、欺诈与欺骗性操作
8. Human Trust Exploitation, Overreliance, and Authority Distortion / 人机信任利用、过度依赖与权威扭曲
9. Resource Exhaustion, Cost Abuse, and Availability Degradation / 资源耗尽、成本滥用与可用性退化
10. Uncontrolled Change, Drift, and Degradation / 非受控变更、漂移与退化
11. Insufficient Monitoring, Traceability, and Accountability / 监控、追溯与问责不足
12. Concentration and Single-Dependency Risk / 集中度与单一依赖风险

该风险模式库刻意保持抽象。组织可在其下维护更细的威胁、滥用或场景分类，但这些细化清单宜映射回这一通用库，以保持治理、保证和审计语言在模型类型与攻击技术持续变化时仍然稳定一致。

2.8 通用控制目标库

组织应在 AI 安全设计和保证活动中统一使用以下控制目标库：

1. Governance and Ownership / 治理与责任归属
2. Use-Case Classification and Admission Control / 用例分类与准入控制
3. Third-Party and Concentration Risk Management / 第三方与集中度风险管理
4. Provenance, Integrity, and Dependency Assurance / 来源、完整性与依赖保证
5. Identity, Credential, and Delegation Governance / 身份、凭据与委托治理
6. Least Privilege and Segmentation / 最小权限与分段隔离
7. Boundary Validation and Context Separation / 边界校验与上下文隔离
8. Data Minimization and Confidentiality Protection / 数据最小化与保密保护
9. Execution Isolation and Action Containment / 执行隔离与行动约束
10. Human Authorization and Reversibility / 人工授权与可逆性
11. Runtime Guardrails, Detection, and Response / 运行时护栏、检测与响应
12. Logging, Evidence, and Investigability / 日志、证据与可调查性
13. Independent Testing and Adversarial Evaluation / 独立测试与对抗性评估
14. Change Control and Revalidation / 变更控制与重新验证
15. Resilience, Fallback, and Safe Degradation / 韧性、回退与安全降级
16. Trust Calibration and Decision Presentation / 信任校准与决策呈现

本控制目标库并不意图与风险模式库形成一一对应关系，而是作为一组可复用的抽象控制家族存在。单一控制目标可以同时映射多个风险模式，而单一风险模式通常也需要多个控制目标共同应对。

这些控制目标刻意保持与具体方案无关。组织可通过不同架构模式、运行模式或供应商产品来实现它们，但每一种实现方式都宜能够被清晰追溯到本控制库中的一个或多个控制目标。

3. 治理、问责与风险承受

3.1 目的

本领域的目的是确保 AI 安全被作为企业风险问题治理，而不是下放给工程团队或模型提供商。组织宜将 AI 安全结果视为管理责任，因为许多高影响失效源于责任不清、例外管理失控、质疑机制薄弱，或在证据不足的情况下因业务压力上线。

3.2 适用范围

本领域适用于 AI 使能系统的治理结构、安全管理、审批机制、风险委员会、模型治理组织、采购决策、政策例外、问题管理和退役决策。

3.3 问题上下文

AI 系统通常跨越职能边界。业务团队可能发起项目，技术团队负责集成，安全团队负责评审，采购团队负责签约，外部服务提供商则可能实质性影响系统行为。若缺乏明确治理，失效通常会落在职能交界处。现实中，组织往往知道是谁构建了某个用例，却不清楚谁有权叫停、约束、降级或正式承受其残余风险。

3.4 主流解决思路

组织通常通过设立 AI 治理机制、将 AI 纳入现有模型风险和网络安全治理、按影响等级采用分层审批、定义明确的例外处理机制，并明确非人身份和委托权限的授权边界来处理本领域问题。更优的模式不是为每个用例建立独立官僚流程，而是采用分层治理模型，使低影响用途保持效率，而高影响、影响客户或能够触发行动的用途则接受更强的质询、证据、审批和撤销阈值。

3.5 风险模式

本领域的主要风险模式是 监控、追溯与问责不足、非受控变更、漂移与退化、集中度与单一依赖风险、滥用、欺诈与欺骗性操作 以及 人机信任利用、过度依赖与权威扭曲。附加风险模式包括 信任边界穿透 和 权限放大与越权行动，其典型情形是治理层面对人员、供应商、身份、审批关口或运行时授权的假设与系统真实行为不一致。

3.6 控制目标

组织应建立以下治理控制目标：

1. Governance and Ownership / 治理与责任归属
组织应为每个重大 AI 用例指定可问责责任人，至少包括业务所有权、技术所有权、安全所有权和正式风险承受授权。
2. Use-Case Classification and Admission Control / 用例分类与准入控制
AI 用例应在部署前完成分类，并在能力、数据、用户群体或下游行动发生重大变化时重新分类。
3. Change Control and Revalidation / 变更控制与重新验证
重大模型、数据、提示、检索、工具或供应商变更应按影响程度触发复审和重新验证。
4. Third-Party and Concentration Risk Management / 第三方与集中度风险管理
组织应识别关键能力是否依赖单一提供商、单一模型、单一云平台或不透明的上游供应商。
5. Identity, Credential, and Delegation Governance / 身份、凭据与委托治理
组织应定义谁有权创建、批准、发放、轮换、撤销和监控 AI 使能系统所使用的非人身份、委托权限、代理凭据和高权限工具授权。

3.7 实施原则

在可行情况下，AI 安全宜嵌入现有企业治理体系，而不是被隔离到一个缺乏问责的创新通道。

残余风险承受宜是明确的、留痕的、时限化的且可复核的。

对影响客户、影响市场、具有法律敏感性或能够触发行动的用例，其残余风险不宜仅由交付团队自行承担。

高影响用例宜接受来自安全、风险、合规或审计职能的独立质询。

重大例外在获批前宜明确适用范围、补偿性控制、到期时间、复审触发条件和撤销条件。

紧急例外机制可以存在，但宜保持范围狭窄、时限明确，并接受事后复审；其不应成为上线的常规路径。

审批流程宜被设计为降低自动化偏见、形式化勾选，以及由看似权威的 AI 输出或界面制造的虚假确定性。

3.8 可审计证据

相关证据包括 AI 用例清单、影响分类结果、审批记录、风险承受记录、例外日志、变更记录、退役程序、供应商依赖评估、身份与委托授权记录、会议纪要以及问题升级链路。

3.9 关键失效方式

常见失效方式包括影子 AI 部署、未经过治理审查即用于高影响客户场景、无授权团队擅自承受风险、对提示、检索逻辑、工具或委托权限的未留痕变更，以及无法识别是谁批准了高风险 AI 能力、批准理由为何、批准何时失效。

3.10 威胁驱动深度指引

治理控制应明确规定威胁情报如何转化为政策、审批阈值和组织权责。MITRE ATLAS 和 OWASP 内容不应只停留在参考资料中，而应影响用例准入、残余风险决策、红队范围、供应商审查、身份授权边界和事件升级阈值。例如，ATLAS 中的 Reconnaissance、Initial Access、Persistence、Defense Evasion、Credential Access 和 Impact 等 tactic，应被用于检验高影响 AI 系统是否可能被发现、进入、操纵、隐藏、滥用凭据并造成影响，而现有治理却无法察觉。

治理中的核心问题不是控制是否写在纸面上，而是在证据恶化或威胁驱动测试失败时，谁有权停止、约束、撤销或降级系统。因此，OWASP LLM 和 Agentic 条目应被转化为明确的政策决策，包括哪些用途需要人工批准、哪些代理动作被禁止、哪些输出需要双重复核、哪些提示、工具、身份或连接器变更构成重大变更，以及哪些失效方式触发管理层通报。

3.11 覆盖映射

覆盖领域	已覆盖的指引要素
第二章视角	生命周期治理、AI 与网络安全交叉域问责、ATLAS 威胁驱动治理、OWASP 防御优先级。
主要风险模式	监控、追溯与问责不足、非受控变更、漂移与退化、集中度与单一依赖风险、滥用、欺诈与欺骗性操作、人机信任利用、过度依赖与权威扭曲。
主要控制目标	治理与责任归属、用例分类与准入控制、变更控制与重新验证、第三方与集中度风险管理、身份、凭据与委托治理。
证据重点	用例清单、风险承受授权、例外记录、红队批准范围、身份与委托授权记录、政策到控制的可追溯性。

3.12 标准映射

本章主要对齐 NIST AI RMF 的 GOVERN、ISO/IEC 42001、ISO/IEC 23894、OWASP Agentic 关于人工批准和最小代理的重点，以及 FSB 2024 和 Bank of England 2025 关于重大风险治理、集中度可视性和高级管理层责任的要求。

3.13 相关场景画像

本治理领域在附录 B 中进一步场景化，尤其对应外部客户聊天与服务、具备工具调用能力的高权限代理、工作流自动化代理、代码助手与开发代理，以及必须明确审批权限、残余风险归属和变更治理的高影响决策支持场景。

3.14 威胁驱动治理映射

威胁驱动关注点	纳入治理的原因	治理重点
过度代理能力	过宽权限往往被当作设计便利而获批，而非基于风险必要性获得正当化。	建立准入标准、最小代理政策、行动型用例的审批阈值，以及定期权限复审。
身份与权限滥用	即使其他地方存在技术控制，薄弱的非人身份治理仍会造成审批缺口。	明确非人身份责任归属、委托权限审批、撤销权以及可复核的凭据生命周期记录。
人机信任利用	如果界面、流程或激励结构鼓励过度信任，人工批准就可能沦为形式。	建立审批质量标准、重大输出双重复核、操作人员培训，以及针对自动化偏见或形式化批准的治理指标。
凭据访问	当没有责任人能够快速暂停委托访问时，凭据受损就会演变为治理问题。	明确凭据暂停权限、事件升级阈值，以及安全、工程和业务责任人的角色边界。
持久化与防御规避	如果治理不把威胁驱动测试失败视为正式复审触发条件，不安全系统就可能因惯性继续留在生产中。	建立强制升级触发条件、临时批准到期机制，以及成文的停止或降级权限。

4. 数据、隐私与知识安全

4.1 目的

本领域的目的是保护敏感数据、维持适当的数据边界、防止非预期泄露，并控制知识源如何被 AI 使能系统引入、存储、检索和暴露。

4.2 适用范围

本领域适用于提示数据、训练数据、微调数据、评估数据、RAG 语料、向量库、记忆系统、日志、输出结果、元数据，以及控制这些数据使用的身份与授权规则。

4.3 问题上上下文

AI 系统泄露数据的方式与传统应用并不完全相同。敏感内容可能通过输出被直接暴露，也可能通过摘要、提示工程、日志、分析系统、检索链路或代理记忆被间接泄露。原本无意对外暴露的数据，一旦被索引、嵌入、混入提示或传给下游工具，就可能变得可推断或可恢复。

从控制设计角度看，本领域应被理解为三个不同的边界层。第一，源数据访问 决定底层记录、仓库和系统哪些可以被触达。第二，检索与记忆使用 决定哪些信息可以被带入模型上下文、被保留，或在多次交互中被复用。第三，输出与日志暴露 决定哪些信息可以被展示、导出、存储，或供后续分析、调查或自动化使用。任一层的控制薄弱都可能抵消其他层更强的控制。

4.4 主流解决思路

常见思路包括基于受批准知识源的检索增强、数据最小化、与用途绑定的访问批准、按敏感度和用途分区、在源系统侧执行访问控制、入库前净化、检索范围约束、限制记忆写入、输出过滤，以及针对高敏感用途的日志控制。任何单一方法都不足够；数据保护取决于源头、检索、提示构造、输出验证、记忆保留和日志留存等多层控制的联合作用。

4.5 风险模式

本领域的主要风险模式是 敏感信息暴露、信任边界穿透、模型或上下文被操纵、输出驱动的下游损害 以及 供应链与来源不透明。当身份、检索或记忆控制薄弱，并使受保护数据被超出预期用途地触达、保留或再次暴露时，也可能出现附加风险模式。

4.6 控制目标

1. Data Minimization and Confidentiality Protection / 数据最小化与保密保护

组织应将 AI 系统可访问的数据限制为完成预期任务所必需的最小范围；除非存在合法且有文档支持的需求，否则不得将某类数据暴露给模型、代理或检索系统。

数据批准应与用途绑定。某类数据被批准用于检索或问答，并不当然意味着同一数据也被批准用于训练、微调、评估、长期记忆、分析或下游自动化。

2. Least Privilege and Segmentation / 最小权限与分段隔离

敏感知识源、客户信息、受监管记录和内部策略应按敏感度、访问人群和业务目的进行分段隔离。

3. Identity, Credential, and Delegation Governance / 身份、凭据与委托治理

组织应定义检索身份、服务账户、委托数据访问权限以及记忆写入权限的批准、作用域、轮换和撤销方式。

4. Provenance, Integrity, and Dependency Assurance / 来源、完整性与依赖保证

组织应了解数据的来源、转换过程以及其是否适合纳入 AI 工作流。

该适用性审查应同时覆盖敏感度和允许用途。适合人工参考、内部检索或狭义决策支持的数据，仍可能不适合被广泛索引、写入代理记忆、用于模型适配，或暴露给外部模型。

5. Logging, Evidence, and Investigability / 日志、证据与可调查性

AI 相关日志应支持调查，同时避免自身演变为不受控的敏感提示、输出或客户信息存储库。

4.7 实施原则

授权宜在底层数据系统中强制执行，而不是仅委托给模型判断。

检索和记忆机制宜具备敏感度感知和人群边界感知。

长期记忆写入宜接受比瞬时提示上下文更严格的信任与授权标准。

对高敏感或受监管用例，不宜默认启用长期记忆；除非存在有文档支持的业务需求和控制设计，否则自动记忆写入应受到限制。

日志宜经过刻意设计，而不是无边界地全量采集。

受监管或高敏感数据在进入微调、长期记忆或广域检索索引前，宜接受更严格审查。

客户身份数据、交易数据、调查材料、合规记录、内部控制文档以及市场敏感信息，在被 AI 复用或被广泛暴露前，宜接受更高等级审查。

4.8 可审计证据

相关证据包括数据清单、分类方案、允许用途规则、检索源审批记录、访问控制映射、身份与委托授权记录、净化规则、记忆保留与删除规则、日志范围、保留策略、提示与输出处理流程，以及泄露和过度暴露测试记录。

4.9 关键失效方式

常见失效方式包括在没有敏感度过滤的情况下广泛索引内部仓库、未经特定批准即将数据复用于模型适配或记忆、默认将客户或受监管数据暴露给外部模型、在分析流水线中保留敏感提示、未经审查即授予宽泛的委托检索权限，以及让模型间接获得下游系统本不允许访问的数据。

4.10 威胁驱动深度指引

数据、隐私和知识控制应同时面向非故意泄露和对手发现行为进行设计。ATLAS 中的 Reconnaissance、Discovery、Collection、Exfiltration 和 AI Attack Staging 与本领域直接相关，因为企业知识库、向量索引、日志和记忆存储既可能成为攻击目标，也可能成为后续攻击的跳板。因此，控制不仅应覆盖源数据访问，也应覆盖数据如何被转换为嵌入、摘要、引用、遥测和长期记忆。

OWASP LLM 和 Agentic 指南将本领域进一步聚焦到 Sensitive Information Disclosure、Vector and Embedding Weaknesses 和 Memory & Context Poisoning。其实含义是，检索授权、语料来源、记忆写入控制、记忆保留、委托数据访问和日志保留必须被视为安全控制，而不是产品或分析决策。

4.11 覆盖映射

覆盖领域	已覆盖的指引要素
第二章视角	生命周期数据治理、Cyber AI 数据保护、ATLAS 发现/收集/外传、OWASP 披露/RAG/记忆控制。
主要风险模式	敏感信息暴露、信任边界穿透、模型或上下文被操纵、输出驱动的下游损害、供应链与来源不透明。
主要控制目标	数据最小化与保密保护、最小权限与分段隔离、身份、凭据与委托治理、来源、完整性与依赖保证、日志、证据与可调查性。
证据重点	数据分类、允许用途规则、检索授权测试、语料来源、记忆写入审计、委托访问授权记录、泄露测试和日志保留设计。

4.12 标准映射

本章主要对齐 NIST AI RMF 的可信特征、ISO/IEC 23894、NIST IR 8596、OWASP LLM Top 10 2025 关于敏感信息披露的主题，以及 SAFE-AI 对嵌入式敏感信息和数据处理的关注。

4.13 相关场景画像

本领域在 附录 B 中进一步场景化，尤其对应内部知识助手、外部客户聊天、RAG 文档问答、摘要与内容生成、欺诈辅助、合规辅助以及高影响决策支持等场景。

5. 模型、组件与供应链安全

5.1 目的

本领域的目的是管理模型、数据集、库、编排组件、外部 API 以及其他上游依赖所带来的安全与可信影响，这些依赖会实质性影响 AI 系统行为。

5.2 适用范围

本领域适用于开放权重模型、专有托管模型、机器学习框架、模型服务栈、提示中间件、嵌入、向量数据库、代理框架、预训练资产、基于 CLI 的执行工具、代理技能、插件、MCP 服务与连接器、Hook、脚本、工具描述符、执行代理，以及所有实质性影响 AI 行为的上游供应商。

5.3 问题上下文

AI 系统经常依赖组织自身并未创建且无法完全检查的不透明上游组件。这些组件可能包括模型权重、训练数据、封闭服务 API、检索库、评估工具包、编排框架，以及插件、技能、CLI 包装层、MCP 连接器、Hook 和脚本等工具集成机制。因此，安全与保证不仅取决于内部工程质量，也取决于组织是否理解其运行内容、来源、变化方式、其引入了哪些权限边界，以及其带来了哪些失效模式。

从治理角度看，本章中的供应链至少应按四类对象理解。第一，模型与数据工件 包括权重、数据集、适配器、提示和评估集。第二，运行时组件与连接器 包括插件、技能、MCP 服务、工具描述符、Hook、脚本和执行代理。第三，托管服务与供应商行为 包括托管 API、模型路由逻辑、供应商控制的服务端策略变化和运行时默认设置。第四，评估与治理工件 包括基准、安保策略、审批模板以及其他会影响依赖是否被接受或被信任的控制工件。

5.4 主流解决思路

组织通常通过尽职调查、依赖清单、受控引入、隔离评估环境、完整性验证、合同约束、分阶段部署、运行时护栏、持续依赖监测以及周期性依赖复评来应对该类问题。最有效的模式不是基于声誉的盲目信任，而是对 AI 供应链实施严格的来源、完整性、变更控制、集中度认知和持续保证。

5.5 风险模式

本领域的主要风险模式是 供应链与来源不透明、模型或上下文被操纵、非受控变更、漂移与退化、集中度与单一依赖风险 以及 权限放大与越权行动。当不透明依赖、供应商默认设置或扩展执行能力的组件在引入后悄然改变权限边界或系统行为时，也可能出现附加风险模式。

5.6 控制目标

1. Provenance, Integrity, and Dependency Assurance / 来源、完整性与依赖保证
组织应维护重大 AI 依赖的现行清单，并评估其来源、完整性、信任假设和更新行为。
2. Use-Case Classification and Admission Control / 用例分类与准入控制
新模型、数据集和代理框架应在进入生产前经过定义明确的审查标准。
3. Third-Party and Concentration Risk Management / 第三方与集中度风险管理
组织应识别那些一旦故障、被攻破、撤出服务或更改条款即会对运营产生重大影响的依赖。
4. Change Control and Revalidation / 变更控制与重新验证
供应商驱动更新、模型替换和依赖升级不应默认被视为低风险维护。
5. Execution Isolation and Action Containment / 执行隔离与行动约束
对来源不可信或理解不足的模型、连接器、工具和编排组件，应先在隔离环境中引入和评估，再允许其影响生产系统。
当插件、技能、CLI 包装层、Hook、脚本、MCP 集成或其他会扩展执行能力的机制能够改变可达系统、可用工具、权限边界或数据流时，本要求同样适用。
6. Independent Testing and Adversarial Evaluation / 独立测试与对抗性评估
对具备重大影响的 AI 依赖，组织应在其进入生产前后，按照其权限范围、不透明程度和运行关键性，实施独立测试、对抗性评估或同等强度的质询机制。

5.7 实施原则

上游不透明性升高时，内部保证要求宜随之提高，而不是降低。

外部模型声誉不应替代内部独立验证。

对来源不明或理解不足的组件，首次接触宜在隔离环境中进行。

供应商合同宜支持可审查性、事件协作、重大变更通知以及运营退出规划。

供应商发放的凭据、连接器或托管执行路径不应绕过内部审批、分段隔离或监控要求。

即便某些依赖是以开发便利功能或平台默认能力的形式引入，只要其会扩展执行能力、工具可达范围或委托权限，就宜将其视为重大变更。

5.8 可审计证据

相关证据包括依赖清单、引入审查记录、来源记录、完整性验证结果、隔离评估记录、架构决策记录、重大变更通知、工具集成审批记录、评估日志以及集中度风险评估。

5.9 关键失效方式

失效方式包括部署来源不清的模型、接受供应商的静默模型变更、在关键客户或控制功能上依赖单一上游提供商、在过权环境中评估新依赖，以及引入会显著扩大运行时权限却未经过相应评审的插件、技能、CLI 工具、Hook、脚本、连接器、库或框架。

5.10 威胁驱动深度指引

本领域是抽象供应链风险变得具体的地方。ATLAS 中关于获取公开 AI 工件、AI 供应链攻陷、不安全 AI 工件、模型投毒和 AI 组件操纵的技术，应被用于定义供应商尽调、引入测试、完整性验证和运行时监控要求。关键问题是组织是否能够证明自己正在运行什么，并能在依赖发生安全相关变化时发现这一点。

OWASP LLM 的 Supply Chain 和 Data and Model Poisoning，以及 OWASP Agentic 的 Agentic Supply Chain Vulnerabilities，将范围扩展到模型权重和库之外。当提示模板、工具描述符、MCP 服务、编排策略、适配器、评估数据集、托管 API 行为、供应商发放的运行时身份，以及插件、技能、CLI 包装层、Hook 和脚本等会扩展执行能力的机制能够塑造系统行为时，它们都应被视为重大依赖。

对于重大金融工作流，外部模型、平台、连接器和执行扩展机制不应被视为不可约化的黑盒。组织宜保留足够的可视性、验证证据、事件协作权以及替代规划，以便在客户、审慎、合规或市场敏感条件下为其持续使用提供正当性。

5.11 覆盖映射

覆盖领域	已覆盖的指引要素
第二章视角	生命周期采购与变更、Cyber AI 保护 AI 系统视角、ATLAS 资源开发/初始访问/持久化/影响、OWASP 供应链与投毒控制。
主要风险模式	供应链与来源不透明、模型或上下文被操纵、非受控变更、漂移与退化、集中度与单一依赖风险、权限放大与越权行动。
主要控制目标	来源、完整性与依赖保证、用例分类与准入控制、第三方与集中度风险管理、变更控制与重新验证、执行隔离与行动约束、独立测试与对抗性评估。
证据重点	AI 物料清单、模型/来源审批、依赖清单、供应商证明、完整性检查、隔离引入、工具集成审批记录、分阶段部署和回滚证据。

5.12 标准映射

本章主要对齐 MITRE SAFE-AI、MITRE ATLAS、OWASP LLM Top 10 2025 关于供应链和投毒的主题、NIST IR 8596，以及 FSB 对集中度和第三方依赖的关注。

5.13 相关场景画像

本领域在附录 B 中进一步场景化，尤其对应代码助手与开发代理、具备工具调用能力的高权限代理、RAG 文档问答，以及建立在第三方模型或托管平台之上的高影响决策支持场景。

5.14 OWASP 威胁画像映射

OWASP 条目	纳入本章的原因	主要控制重点
供应链	覆盖被攻破的模型、适配器、库、仓库、第三方 API、托管服务以及上游提供商策略变化。	依赖清单、来源审查、完整性校验、供应商尽调、分阶段引入和退出规划。
数据与模型投毒	覆盖训练数据、微调输入、评估集、RAG 语料以及通过上游篡改造成的模型行为污染。	来源可信控制、数据策展、隔离、完整性监测、重新验证和可疑变化调查。
代理式供应链脆弱性	将供应链风险扩展到代理框架、MCP 描述符、编排工件、工具元数据、插件、Hook、脚本、连接器以及代理使用的非人身份。	签名工件要求、描述符校验、工具来源可信、受控扩展引入、隔离评估和持续依赖审查。

6. 应用、提示、上下文与输出安全

6.1 目的

本领域的目的是保护应用层安全，即输入被接收、上下文被拼装、提示被构建、模型被调用、输出被呈现以及下游系统受到影响的那一层。该领域之所以核心，是因为许多企业 AI 事件并非基础模型单独失效，而是应用逻辑失败：信任了错误内容、错误混合了指令，或让未经验证的输出产生了下游影响。

6.2 适用范围

本领域适用于聊天应用、RAG 界面、文档摘要器、副驾驶、知识助手、代码助手、分类流水线、多模态界面，以及任何将模型输出转化为用户可见结果或系统可执行结果的应用。

6.3 问题上下文

企业 AI 应用经常在单一推理链中混合多种内容类型和信任等级：系统提示、开发者指令、用户输入、检索文档、工具输出、隐藏元数据和会话历史。如果应用不能维持清晰的控制边界，不可信内容就可能改变行为、未经审查的输出就可能驱动行动、敏感上下文也可能泄露。在代理式或高度依赖检索的系统中，由于模型能快速接触大规模语料和多个工具，该问题会变得更严重。

从控制角度看，本领域应被理解为三层。第一，输入与上下文控制 决定模型可以看到什么，以及指令如何与数据分离。第二，输出与呈现控制 决定应用可以展示、执行、存储或传输什么。第三，用户信任与解释控制 决定用户如何理解哪些内容是生成的、哪些是检索的、哪些已经验证、以及哪些仍需人工判断。

应用不应将模型作为最终策略权威。凡是可以在应用边界、检索层、执行包装层或下游系统中以确定性方式作出的控制决策，均宜在那里作出，而不宜委托给模型判断。

6.4 主流解决思路

常见方案包括提示模板、策略层、结构化输出约束、检索过滤、来源标记、工具中介、在用户界面中分隔可信与不可信内容、面向信任校准的呈现方式，以及对高风险输出进行执行前复审。组织宜组合采用这些思路，而不是假设任何单一措施就能解决提示注入、上下文混淆、不安全输出处理或对有说服力内容的过度信任问题。

在暴露面更大或风险更高的应用中，上述模式可通过语义校验和策略执行层来实现，以便在内容被信任或向下游传播前，检查提示上下文、检索材料、工具参数和输出意图。本指引不强制要求某一特定产品类别，但这类控制在实践中常被称为 AI 语义防火墙。

6.5 风险模式

本领域的主要风险模式是 信任边界穿透、模型或上下文被操纵、权限放大与越权行动、输出驱动的下流损害、敏感信息暴露 以及 人机信任利用、过度依赖与权威扭曲。当检索内容、生成式理由或界面设计将不确定性压缩成虚假信心，或诱发不安全下游行动时，也可能出现附加风险模式。

6.6 控制目标

1. Boundary Validation and Context Separation / 边界校验与上下文隔离
应用应区分系统指令、开发者策略、用户请求、检索内容和工具返回内容，并防止不可信材料被当作权威系统控制输入。
2. Data Minimization and Confidentiality Protection / 数据最小化与保密保护
仅应向模型暴露完成当前任务所需的最小上下文；隐藏指令或敏感系统细节不得通过正常响应路径泄露。
3. Human Authorization and Reversibility / 人工授权与可逆性
影响记录、权限、交易或面向客户决策的高风险输出，在产生实质性影响前应接受额外验证或人工批准。
对具有重大说服力、面向客户、面向分析师或影响决策的输出，不得以超出有证据支持程度的方式呈现为已验证、具权威性 or 高度确定。
4. Logging, Evidence, and Investigability / 日志、证据与可调查性
应用应保留足够证据，以便为调查和复核重建提示上下文、检索来源、工具调用和输出处理决策。
5. Independent Testing and Adversarial Evaluation / 独立测试与对抗性评估

应用应接受提示注入、上下文混淆、信息泄露、不安全输出处理和跨边界操纵方面的测试。

6. Runtime Guardrails, Detection, and Response / 运行时护栏、检测与响应

高风险应用流程应包含运行时检查能力，以便在产生实质性影响前，对可疑提示、不安全工具参数、有害输出意图或规避策略的交互模式执行暂停、阻断、升级或隔离。

7. Trust Calibration and Decision Presentation / 信任校准与决策呈现

影响客户理解、分析师判断、审批决策或运营行动的应用，应以清晰区分的方式呈现生成内容、检索内容、已验证证据以及尚未消除的不确定性。

6.7 实施原则

不可信上下文宜被视为数据，而不是策略。

模型输出宜被视为需要解释的陈述，而不是需要服从的命令。

下游授权宜由受控系统强制执行，而不应依据模型置信度或输出格式推断。

用户界面宜帮助用户理解哪些内容是生成的、检索的、引用的或已由系统验证的。

用户界面宜明确校准信任，不应将生成式理由、格式完整性或语言流畅性呈现为正确性的证据。

面向客户、面向分析师以及支持审批的界面，宜清晰区分已验证来源、生成文本、未经验证的陈述以及仍需人工判断的部分。

多模态输入即便对人类看似无害，也宜被视为可能携带与控制相关的载荷。

在高风险流程中，应在授予信任之前，对检索内容、工具返回内容或模型生成内容实施语义边界校验。

面向客户、面向分析师以及支持审批的输出，宜避免不当确定性信号、伪造性理由，或将未解决不确定性压缩成虚假信心的呈现方式。

6.8 可审计证据

相关证据包括提示与策略架构、检索源规则、输出验证逻辑、运行时护栏规则、工具中介控制、界面标识与披露逻辑、面向客户或分析师的呈现规则、红队结果、泄露测试、审计日志，以及高风险动作人工批准或双重复核记录。

6.9 关键失效方式

失效方式包括直接和间接提示注入、隐藏在检索文档或多模态内容中的指令、系统提示泄露、模型输出的不安全呈现、模型输出未经验证即触发下游执行，以及用户过度依赖或误以为系统已验证实际上未验证的内容。

6.10 威胁驱动深度指引

AI 应用层安全应假设自然语言、文档、网页、图像、代码片段和工具输出都可能携带对抗性指令。ATLAS 中关于提示注入、提示渗透、延迟指令执行、AI 模型规避和通过 AI 服务外传的技术，与本领域直接相关。防御设计目标是将指令、数据、检索上下文、生成输出和可执行效果保持在不同信任区中。

OWASP LLM 指南在本领域尤其核心：提示注入、敏感信息披露、不当输出处理、系统提示泄露、向量与嵌入弱点以及错误信息，首先是应用设计问题，其次才是模型问题。因此，控制应尽可能在应用边界以确定性方式执行，模型判断只能作为补充信号，而不应成为最终策略权威。这也是必须把“信任校准”视为控制要求而非体验偏好的章节。

6.11 覆盖映射

覆盖领域	已覆盖的指引要素
第二章视角	Cyber AI 安全应用视角、ATLAS 执行/规避/收集/外传、OWASP LLM 防御优先级。
主要风险模式	信任边界穿透、敏感信息暴露、模型或上下文被操纵、输出驱动的下游损害、人机信任利用、过度依赖与权威扭曲。
主要控制目标	边界校验与上下文隔离、数据最小化与保密保护、人工授权与可逆性、运行时护栏、检测与响应、信任校准与决策呈现。
证据重点	提示注入测试、上下文标记规则、输出验证测试、运行时干预记录、RAG 授权检查、错误信息与引用评估以及信任校准审查。

6.12 标准映射

本章主要对齐 OWASP Top 10 for LLM Applications 2025、OWASP Top 10 for Agentic Applications 2026、MITRE ATLAS、NIST IR 8596、SAFE-AI，以及 NIST AI RMF 的 MAP、MEASURE 和 MANAGE。

6.13 相关场景画像

本领域在 附录 B 中进一步场景化，尤其对应外部客户聊天、RAG 文档问答、内部知识助手、摘要与内容生成，以及合规审查辅助场景。

6.14 OWASP 威胁画像映射

OWASP 条目	纳入本章的原因	主要控制重点
提示注入	典型应用层失效，不可信输入、检索文档、网页、文件或多模态内容覆盖原定指令。	边界校验、上下文隔离、语义过滤、来源标记和对抗测试。
敏感信息披露	覆盖通过输出、摘要、提示上下文、日志、记忆或检索发生的直接和间接信息披露。	数据最小化、脱敏、输出复核、检索范围约束和面向用户的安全交互设计。
不当输出处理	覆盖对模型生成的 SQL、代码、HTML、命令、路径、邮件或工作流指令的不安全呈现或执行。	结构化输出、下游校验、策略执行、转义与净化以及执行关口。
系统提示泄露	覆盖隐藏指令、嵌入式密钥、特权策略暴露，以及将提示文本误当安全边界。	避免在提示中放置密钥、将确定性控制外置、最小化隐藏上下文并测试抗提示提取能力。
向量与嵌入弱点	覆盖 RAG 系统中的检索投毒、未授权语料混合、命名空间隔离薄弱，以及嵌入层泄露或混淆。	检索卫生、租户隔离、来源信任评分、记忆与检索校验以及语料治理。
错误信息	覆盖貌似可信但错误的内容、捏造理由，以及在面向用户或分析师的流程中对生成内容的过度依赖。	来源锚定、不确定性披露、人工复核、界面信任校准和可质疑的证据链。

7.代理、工具与行动安全

7.1 目的

本领域的目的是控制能够规划、选择工具、调用外部能力、修改状态或在较少人工监督下行动的 AI 系统。代理式行为会显著改变风险，因为模型不再只是生成内容；它还可能选择行动、编排任务，并与会产生持久后果的系统交互。

7.2 适用范围

本领域适用于 AI 代理、具备行动能力的副驾驶、工作流自动化代理、使用工具的助手、可执行代码的系统、浏览代理、可调用 CLI 的系统、基于技能和插件扩展的代理、由 AI 决策触发的 Hook 与脚本、通过 MCP 连接的代理、由连接器驱动的工作流，以及可以在企业环境中创建、更新、删除、批准或传输信息与指令的系统。

7.3 问题上下文

当 AI 系统获得工具访问能力时，许多传统护栏会减弱。模型可能选择错误工具、将正确工具用于错误目的、将多个低风险步骤串联为高风险结果、放大提示注入后果，或利用授权中的模糊地带。由于工具将 AI 系统连接到真实数据和真实系统，失效模式会从信息错误扩展到运营性受损。

这同样适用于现代代理工具机制，例如 CLI 包装层、技能、插件、Hook、脚本、MCP 集成和连接器。这些机制不只是实现细节；在运行时，它们定义了代理可以触达什么、可以执行什么、可以使用哪些身份，以及不安全动作能以多快速度传播。

从运行时控制角度看，这些机制应被理解为行动面。它们承载参数、身份、副作用、链式调用逻辑、网络可达性和状态变更能力。如果将其视为便利功能而非执行边界，就会直接导致策略绕过、权限过大和事件遏制能力不足。

7.4 主流解决思路

常见方案包括工具白名单、狭义技能设计、策略强制执行包装器、行动确认、作用域凭据、即时权限发放、默认只读、环境隔离、费用和速率限制，以及“模型提出、人工或受控系统授权”的工作流拆分。

对于风险更高的代理，上述模式宜与系统级沙箱、隔离执行代理、即时发放凭据以及执行前策略校验结合使用，并将代理计划和工具请求在验证前一律视为不可信。

7.5 风险模式

本领域的主要风险模式是 权限放大与越权行动、信任边界穿透、输出驱动的下游损害、模型或上下文被操纵、滥用、欺诈与欺骗性操作、资源耗尽、成本滥用与可用性退化以及 人机信任利用、过度依赖与权威扭曲。当链式工具调用、委托凭据或多步计划将局部低风险动作转化为更广泛的运营效果时，也可能出现附加风险模式。

7.6 控制目标

1. Least Privilege and Segmentation / 最小权限与分段隔离
代理和具备工具能力的系统应仅获得执行特定任务所需的最小身份、令牌、数据范围和行动权限。
2. Human Authorization and Reversibility / 人工授权与可逆性
影响客户、记录、资金、代码、权限、通信或监管义务的重大行动应要求明确批准或同等强度的受控关口。
3. Boundary Validation and Context Separation / 边界校验与上下文隔离
工具请求应通过具备策略感知能力的执行层进行中介，而不是直接由原始模型输出执行。
该中介要求应适用于 CLI 调用、技能执行、插件调用、Hook 或脚本触发、连接器使用、MCP 工具调用以及其他会产生效果的运行时集成。
4. Resilience, Fallback, and Safe Degradation / 韧性、回退与安全降级
当缺失必要信息、策略检查失败、工具行为异常或下游系统拒绝请求时，代理应以安全方式失败。
5. Logging, Evidence, and Investigability / 日志、证据与可调查性
工具使用、行动提议、批准、拒绝、回滚和环境变更应能够通过日志重建。
6. Identity, Credential, and Delegation Governance / 身份、凭据与委托治理
代理、工具和执行代理应使用具备作用域、可归因且可撤销的身份与凭据；委托权限应针对预期行动类别获得明确批准。
7. Execution Isolation and Action Containment / 执行隔离与行动约束
具备代码执行能力的工具、Shell 访问、浏览器自动化、工作流执行以及其他会产生效果的动作，应由隔离且执行策略的执行层约束，而不是直接受原始模型输出驱动。

8. Runtime Guardrails, Detection, and Response / 运行时护栏、检测与响应

代理计划、工具调用、委托行动和自主循环应被监测，以发现不安全漂移、异常重复、策略绕过和可疑升级，并应配套定义停止、撤销和遏制动作。

7.7 实施原则

在可以采用目的明确的权限时，宜避免开放式权限。

不宜依赖代理自行决定其授权边界。

批准宜针对实际效果，而不仅仅针对提示文本。

技能、插件、脚本、CLI 包装层和连接器等工具机制宜被视为执行路径进行治理，而不是被视为无害的便利功能。

在业务允许时，宜优先采用可逆操作而非不可逆操作。

代理记忆、规划轨迹和工具结果宜被视为与安全相关的状态。

委托凭据宜具备短时效、明确作用域、可归因性以及快速撤销能力。

在可行时，高影响工具执行和代码执行宜仅发生在隔离、可撤销且可观测的执行环境中。

7.8 可审计证据

相关证据包括工具清单、插件与技能清单、CLI 包装层清单、Hook 与脚本审批记录、MCP 与连接器审批记录、权限映射、执行包装层、审批 workflow、回滚机制、行动日志、沙箱配置、委托凭据发放与撤销记录、速率和费用限制，以及针对目标劫持、工具滥用、权限升级和不安全链式调用的测试。

7.9 关键失效方式

失效方式包括过度代理能力、宽泛的 Shell 或 API 执行权限、不安全的 CLI 或脚本执行路径、绕过预期策略检查的插件或技能行为、将数据可达范围扩展到批准范围之外的连接器或 MCP 调用、工具链绕过预期审查、过期或失管的委托权限、对代理记忆或规划的间接提示注入、无法区分模型提议与已批准行动，以及缺乏紧急停止或撤销机制。

7.10 威胁驱动深度指引

代理式系统应被作为行动系统分析，而不仅是对话系统。ATLAS 中涉及 AI 代理工具调用、通过工具调用外传、通过工具调用破坏数据、凭据收集、逃逸到宿主机、命令生成以及失控或持久化代理的技术，应被用作高权限代理的测试假设。组织应假设，如果工具权限过宽，代理能够把薄弱的指令边界转化为真实系统影响。

该分析还应显式覆盖 CLI 包装层、技能、插件、Hook、脚本、MCP 工具和连接器等运行时机制。在运行时，这些机制决定的并不只是代理可以说什么，还决定其可以执行什么、可以触达哪些系统，以及可以改变哪些状态。

OWASP Agentic 指南将 `least-agency` 作为核心原则：对某项任务而言，最安全的代理往往是并不需要自主性的代理。当自主性确有必要时，最低可辩护控制集应包括作用域身份、受限工具、执行前策略检查、隔离执行、可观测工具使用、重大影响动作的人工批准，以及经过测试的撤销或停止路径。

7.11 覆盖映射

覆盖领域	已覆盖的指引要素
第二章视角	ATLAS 执行/权限提升/横向移动/外传/影响、OWASP Agentic 防御优先级、International AI Safety Report 对代理风险的关注。
主要风险模式	权限放大与越权行动、信任边界穿透、模型或上下文被操纵、输出驱动的下游损害、滥用、欺诈与欺骗性操作、人机信任利用、过度依赖与权威扭曲、资源耗尽、成本滥用与可用性退化。
主要控制目标	最小权限与分段隔离、人工授权与可逆性、边界校验与上下文隔离、韧性、回退与安全降级、日志、证据与可调查性、身份、凭据与委托治理、执行隔离与行动约束、运行时护栏、检测与响应。
证据重点	工具清单、插件与技能清单、连接器审批记录、权限映射、行动批准记录、委托凭据生命周期记录、沙箱配置、工具调用日志以及停止开关或回滚测试。

7.12 标准映射

本章主要对齐 OWASP Top 10 for Agentic Applications 2026、OWASP LLM Top 10 2025 关于过度代理的主题、MITRE ATLAS、International AI Safety Report 2026 对代理与工具使用的分析，以及 NIST IR 8596 关于保护 AI 与 AI 赋能防御的关注点。

7.13 相关场景画像

本领域在 附录 B 中进一步场景化，尤其对应工作流自动化代理、具备工具调用能力的高权限代理、代码助手与开发代理，以及具备行动能力的客户或员工助手场景。

7.14 OWASP 威胁画像映射

OWASP 条目	纳入本章的原因	主要控制重点
过度代理能力	覆盖向模型或代理授予超出用例所需的权限、工具访问或下游影响力。	最小权限、审批关口、作用域工具和模型外部的下游授权。
代理目标劫持	覆盖通过提示操纵、恶意工件、欺骗性工具输出或被污染外部输入导致的代理目标偏转。	意图校验、计划偏移检查、高影响审批以及对目标变化的运行时漂移告警。
工具滥用与利用	覆盖合法工具被滥用、不安全串联、过宽 API 权限、工具投毒和代理驱动的数据外流。	工具白名单、系统级沙箱、语义校验、逐工具策略执行、速率预算和不可变日志。
意外代码执行	覆盖对生成或转发的代码、Shell 命令、脚本、解释器以及可执行代码工具链的不安全执行。	隔离执行环境、禁止直接执行原始模型输出、限制外联以及快速撤销能力。
记忆与上下文投毒	覆盖代理记忆、摘要、RAG 状态或长期上下文的持续污染，并在后续驱动不安全规划或工具使用。	记忆分段、可信摄入规则、禁止自动自回灌、隔离与回滚以及基于信任的检索加权。
不安全的代理间通信	覆盖协作代理之间被伪造、篡改、重放或语义操纵的消息。	消息认证、完整性保护、协议校验、作用域信任关系和通信可审计性。

8. 身份、基础设施与运行环境安全

8.1 目的

本领域的目的是保护 AI 系统运行的环境、其依赖的身份体系，以及其暴露、管理、监控和更新所经过的基础设施路径。

8.2 适用范围

本领域适用于云和本地基础设施、容器、终端、凭据、密钥、网络、管理路径、推理服务、开发环境、构建与部署流水线，以及外部服务访问。在相关场景下，它还适用于自建 AI Factory 和 GPU 集群，包括加速器、基于 NVLink 或 NVSwitch 互联的系统、InfiniBand 或 Ethernet 网络、RDMA 或 GPUDirect 数据路径、DPU 或 SmartNIC 层、存储网络、调度器、集群管理器，以及带外管理平面。在本章中，这一面向自建集群和数据中心的专门关注点称为 AI Infra Security。

8.3 问题上下文

8.3.1 AI 基础设施安全关注重点

AI 安全往往承继传统基础设施风险，同时扩大攻击面。高价值模型资产、敏感数据存储、强权限服务账户和对外暴露的交互入口都构成高吸引力目标。在很多组织中，AI 环境发展速度极快，可能绕过既有强化基础设施模式，留下身份管理薄弱、管理权限过宽和分段隔离不足等问题。

自建 AI Factory 和 GPU 集群会再引入一层暴露面，因为它们依赖的是为吞吐量和时延优化的专用计算、网络与存储路径，而不是首先围绕传统企业信任边界设计的路径。集群调度器、GPU 供给服务、DPU 控制平面、带外管理路径、固件更新通道，以及训练或推理网络中的东西向流量，都会成为高价值攻击面。

像 RDMA、RoCE、InfiniBand、GPUDirect RDMA、GPUDirect Storage 和 NVMe-over-Fabrics 这样的高速数据路径，也会削弱“所有关键控制或检测都发生在主机 CPU 或传统应用遥测层”的简单假设。若仅把这些路径当作性能特性对待，组织就可能遗漏直接内存访问风险、租户串扰、控制平面分离不足、通过 fabric 的横向移动，或高影响数据移动缺乏足够可观测性等问题。

本领域应从三类基础设施控制关注点理解。第一，身份生命周期控制 治理人类和非人身份的发放、认证、委托、轮换和撤销。第二，执行环境控制 治理模型服务、工具执行、浏览器自动化、脚本、连接器和具备代码执行能力的运行时可以在何处运行。第三，服务间信任控制 治理代理、工具、连接器、API 和内部平台如何跨网络边界进行认证、授权和数据交换。

8.4 主流解决思路

常见方案包括零信任身份控制、密钥隔离、分段的运行环境、强化的管理路径、环境特定凭据、即时访问、工作负载隔离、针对高风险执行路径的系统级沙箱、安全的构建与部署流水线、服务间信任控制、外联控制，以及对公共 AI 接口的更强可观测性。

对于 AI Factory 和 GPU 集群，常见方案还包括显式分离计算网、存储网、带内管理网和带外管理网；强化调度器与集群控制平面；对 RDMA 和直接内存路径实施策略化治理；使用基于 DPU 或等价方式的基础设施隔离；采用经过验证的参考架构；对固件、驱动和镜像实施受控生命周期管理；按租户进行存储与命名空间隔离；在有必要时实施节点或工作负载证明；以及从主机、fabric、DPU 和存储层获取独立遥测。

8.5 风险模式

本领域的主要风险模式是 信任边界穿透、权限放大与越权行动、敏感信息暴露、供应链与来源不透明、集中度与单一依赖风险 以及 资源耗尽、成本滥用与可用性退化。当身份生命周期控制薄弱、分段隔离不足、执行隔离不充分，或高速数据路径治理薄弱，并使基础设施受损进一步演变为 AI 受损时，也可能出现附加风险模式。

对于自建 AI Factory 和 GPU 集群，第 2 章中的通用控制目标宜被具体化到高速 fabric、直接内存路径、集群控制平面及相关基础设施信任边界之上。这些专门关注点属于通用控制库在本章中的领域化展开，而不是对主控制库的单独新增。

8.6 控制目标

1. Identity, Credential, and Delegation Governance / 身份、凭据与委托治理

AI 系统使用的人类和非人身份应具备明确作用域、可归因性、在适当情况下采用强认证、可被快速撤销，并在全生命周期中接受治理。

2. Least Privilege and Segmentation / 最小权限与分段隔离

AI 环境、管理路径和敏感服务应进行分段隔离，特权访问应被最小化并采用强认证。

对 AI 网络和直接内存路径，包括 RDMA、RoCE、InfiniBand、GPUDirect 以及基于 fabric 的存储通道，组织应明确将其视为与安全相关的边界进行治理；在必要时实施分段隔离；且不得仅因其为高性能优化路径而被默认信任。

3. Execution Isolation and Action Containment / 执行隔离与行动约束

具备代码执行能力的运行时、浏览器执行、解释器、模型服务扩展以及其他高影响执行路径，应通过显式策略、外联控制和撤销能力进行隔离与约束。

4. Provenance, Integrity, and Dependency Assurance / 来源、完整性与依赖保证

AI 服务的构建、发布和运行路径应防范篡改和未授权替换。

5. Logging, Evidence, and Investigability / 日志、证据与可调查性

管理访问、模型部署变更、凭据使用和公共端点活动应具备可观测性和可归因性。

对于自建 AI Factory 和 GPU 集群，在有必要时，可观测性还应覆盖来自主机、fabric、DPU、存储层或等价基础设施平面的独立遥测，而不应仅依赖应用日志。

6. Resilience, Fallback, and Safe Degradation / 韧性、回退与安全降级

基础设施故障或提供商不可用不应导致非受控行为或不安全回退。

7. Runtime Guardrails, Detection, and Response / 运行时护栏、检测与响应

身份滥用、异常执行模式、沙箱逃逸、可疑外联以及公共入口滥用应可被检测，并与预定义的遏制动作相连接。

8.7 实施原则

AI 系统宜继承企业既有强化标准，除非存在已审查的例外理由。

对外交互入口宜被视为敌对输入边界。

当模型和提示资产一旦暴露会提高攻击成功率时，宜将其视为敏感运营资产处理。

开发便利不应成为持续使用共享密钥、失管凭据或高权限服务身份的理由。

零信任假设宜适用于用户、代理、工具、工作负载以及服务间通信的各个层面。

当非人身份所持权限具有重大影响时，其发放和撤销宜比照人类特权访问的严格程度进行治理。

对高速网络和直接内存路径而言，性能优化不应凌驾于分段隔离、策略执行、来源控制或可观测性之上。

8.8 可审计证据

相关证据包括网络与身份架构、特权访问设计、非人身份清单、委托权限映射、密钥管理控制、沙箱和外联策略、服务间信任策略、部署流水线控制、端点可观测性、云配置，以及与基础设施相关的 AI 事件记录。对于 AI Factory 和 GPU 集群，还应包括 fabric 拓扑和分离记录、RDMA 与 GPUDirect 配置基线、DPU 或 SmartNIC 运行模式、固件与驱动基线、调度器与集群角色映射、节点供给记录、在使用时的证明记录、存储命名空间控制，以及来自计算、网络与存储平面的独立遥测。

8.9 关键失效方式

失效方式包括对外 AI 服务在无分段隔离情况下连接内部资源、长期凭据被嵌入 AI 工作流、失管的委托身份、管理接口通过弱控制路径暴露、无法快速撤销或轮换模型服务权限、东西向 AI fabric 扁平化且控制平面分离薄弱、RDMA 或直接内存路径在缺乏显式策略下跨越信任边界、不安全的固件或驱动更新实践、调度器权限过宽，以及允许工作负载或租户间串扰的多租户存储或检索路径。

8.10 威胁驱动深度指引

身份与基础设施控制是遏制 AI 特有失效的基础。ATLAS 中涉及有效账户、凭据转储、替代认证材料、沙箱规避、逃逸到宿主机、机器攻陷以及通过 AI 服务进行命令与控制的技术，应被用于测试当 AI 工作流、代理、模型服务路径或自建 AI 集群 fabric 被引入后，传统基础设施控制是否仍然有效。

OWASP Agentic 中关于身份滥用、意外代码执行、代理间通信和代理式供应链攻陷的条目，都依赖基础设施层面的遏制能力。实践中，这意味着非人身份、工具运行时、沙箱、网络外联、构建流水线、服务间通信通道、调度器、集群管理器、DPU 控制平面以及高速内存或存储路径，都应被作为一等 AI 安全边界管理。

8.11 覆盖映射

覆盖领域	已覆盖的指引要素
第二章视角	Cyber AI 安全基础设施、ATLAS 凭据访问/权限提升/横向移动/防御规避/影响、OWASP 身份与执行控制。
主要风险模式	信任边界穿透、权限放大与越权行动、敏感信息暴露、供应链与来源不透明、集中度与单一依赖风险、资源耗尽、成本滥用与可用性退化。
主要控制目标	身份、凭据与委托治理、最小权限与分段隔离、执行隔离与行动约束、来源、完整性与依赖保证、日志、证据与可调查性、韧性、回退与安全降级、运行时护栏、检测与响应。
证据重点	身份架构、非人身份清单、委托权限映射、沙箱策略、外联策略、服务间信任控制、密钥轮换、执行环境控制、部署流水线控制、端点可观测性、fabric 拓扑、直接内存路径控制、调度器角色设计以及 DPU 或存储平面遥测。

8.12 标准映射

本章主要对齐 NIST IR 8596、NCSC 安全 AI 开发指南、盟国网络机构联合发布的安全部署指导、SAFE-AI 对系统要素的处理方式，以及标准企业零信任与基础设施强化原则。对于自建 AI Factory 或 GPU 集群中的 AI Infra Security 落地，组织还可以参考 NVIDIA Enterprise AI Factory Validated Design、NVIDIA Spectrum-X Ethernet、BlueField Modes of Operation、DOCA Argus Service Guide、NVIDIA AI Factory for Government - Security 以及 NVIDIA Secure AI with Blackwell and Hopper GPUs 提供的运行与架构指导。

8.13 相关场景画像

本领域在附录 B 中进一步场景化，尤其对应代码助手与开发代理、具备工具调用能力的高权限代理、外部客户聊天、自建 AI Factory 或 GPU 集群，以及任何依赖公共入口、高价值凭据或敏感内部数据路径的场景。

8.14 OWASP 威胁画像映射

OWASP 条目	纳入本章的原因	主要控制重点
身份与权限滥用	覆盖凭据继承、代理身份混淆、过权非人身份以及委派链滥用。	零信任身份、作用域非人身份、强认证、即时凭据和严格撤销机制。
意外代码执行	当执行通过 Shell、解释器、构建代理或运行时逃逸路径发生时，它也具有基础设施维度。	沙箱强化、工作负载隔离、外联控制、管理路径强化和运行时遏制。
不安全的代理间通信	在消息传输、服务身份、发现和路由通道方面，它具有基础设施和信任边界维度。	双向认证、通道完整性、协议强化、网络分段和流量可观测性。

9. 可观测性、保证、韧性与事件响应

9.1 目的

本领域的目的是确保组织能够观测有害变化、调查事件、持续挑战原有假设，并在 AI 系统失效、漂移、遭受攻击或运行不可靠时维持安全且有韧性的运行。

9.2 适用范围

本领域适用于运行时可观测性、评估、红队、异常检测、模型与提示变更审查、事件管理、回滚程序、业务连续性、灾难恢复和事件后学习。

9.3 问题上下文

AI 系统即使没有明显代码变更，也可能发生退化。模型可能因为新的提示、新的用户群体、新的数据分布、新的供应商或新的集成逻辑而表现不同。同一系统可能在低流量时安全、在高流量时失效，也可能在部署前测试中看似受控，却在工具、数据和外部行为者交互后变得不安全。因此，可观测性不能仅限于基础设施可用性或传统应用日志。

本领域应区分五类运行职能。遥测 负责采集系统正在做什么。检测 负责识别不安全或异常状态。调查 负责重建其发生原因。响应 负责遏制或逆转有害效果。学习 负责更新控制、阈值和部署假设。如果这些职能被混在一起，组织往往只是在收集日志，而无法获得可用的运行控制能力。

9.4 主流解决思路

常见方案包括运行时遥测、行为基线、针对异常和滥用的检测、运行时策略执行、周期性和事件驱动的重新评估、红队、质量与安全漂移检查、回滚路径、身份暂停与撤销流程、影子部署、分阶段发布、事件处置手册以及结构化事件复盘。最成熟的模式是将技术可观测性与组织层响应阈值、遏制权限和升级责任结合起来。

9.5 风险模式

本领域的主要风险模式是 非受控变更、漂移与退化、 监控、追溯与问责不足、 输出驱动的下游损害、 滥用、欺诈与欺骗性操作 以及 集中度与单一依赖风险。

高规模推理滥用、失控代理循环、级联失效以及人类过度信任信号也应被视为可观测性关注点，因为它们会迅速将局部故障演变为运营中断或不安全决策依赖。

9.6 控制目标

- Logging, Evidence, and Investigability / 日志、证据与可调查性
在对敏感数据进行合法且适度处理的前提下，组织应保留足够信息，以便重建模型输入、检索上下文、工具行动、输出、审批和重大状态变化。
- Independent Testing and Adversarial Evaluation / 独立测试与对抗性评估
高影响用例应在部署前以及之后定期接受评估，其中包括对抗性、滥用和误用场景。
- Resilience, Fallback, and Safe Degradation / 韧性、回退与安全降级
当置信度、完整性、可用性或策略合规性丧失时，组织应定义 AI 服务如何降级、切换、回退或交还人工处理。
- Change Control and Revalidation / 变更控制与重新验证
可观测性不仅应发现中断，还应发现需要复审的重大行为变化。
- Runtime Guardrails, Detection, and Response / 运行时护栏、检测与响应
组织应为提示攻击、不安全工具使用、资源滥用、级联失效和可疑代理行为定义检测、分诊、遏制和恢复动作。
- Identity, Credential, and Delegation Governance / 身份、凭据与委托治理
可观测性与响应流程应包含追踪、暂停、撤销和重新发放与可疑或不安全行为相关的非人身份、委托权限和代理凭据的能力。

9.7 实施原则

可观测性宜衡量行为和效果，而不仅是基础设施健康状态。

事件响应宜包含 AI 特有的遏制动作，包括禁用工具、隔离知识源、冻结模型变更或强制人工复核。

重新验证宜由有意义的变化触发，而不仅是日历周期。

运行回滚宜被演练，而不只是写在文档中。

运行时护栏宜能够在不安全行为扩散成系统性问题之前，对其进行暂停、限流、撤销或隔离。

检测宜与权限相联动；如果系统能够观察到不安全的代理或身份行为，就应能够在职责不含糊的前提下触发遏制或升级。

可观测性宜覆盖模型行为、代理计划、工具调用、委托身份、连接器活动、记忆变更、策略干预和下游效果，而不应只关注提示或基础设施指标。

9.8 可审计证据

相关证据包括可观测性架构、遥测模式、异常阈值、行为基线、评估计划、红队结果、事件处置手册、回滚程序、身份撤销记录、事件复盘、服务依赖图，以及说明如何发现、解释并处理不安全状态的记录。

9.9 关键失效方式

失效方式包括只能发现中断却发现不了不安全输出、缺少重建有害决策所需日志、无法快速禁用工具使用或撤销代理身份、对已更新的供应商模型继续盲目信任而不重新评估，以及当 AI 支持不可用或不安全时没有经过测试的人工作业回退方案。

9.10 威胁驱动深度指引

可观测性与响应应同时围绕模型行为和对手行为设计。ATLAS 中的 Defense Evasion、Command and Control、Exfiltration 和 Impact 可用于定义检测覆盖：组织应知道，如果攻击者通过 AI 服务进行控制、在记忆中隐藏恶意提示、通过工具外传数据，或通过代理动作造成运营损害，系统应能观察到什么。

OWASP LLM 的 Unbounded Consumption 以及 Agentic 的 Cascading Failures、Human-Agent Trust Exploitation 和 Rogue Agents 表明，AI 事件不只是机密性事件，也可能是成本事件、可用性事件、信任事件、行为事件或多系统传播事件。因此，事件响应应包括 AI 特有遏制动作，例如禁用工具、冻结记忆写入、隔离检索源、限制推理、撤销代理身份以及强制人工复核。

9.11 覆盖映射

覆盖领域	已覆盖的指引要素
第二章视角	生命周期 TEVV 与可观测性、Cyber AI 防御与遏制、ATLAS 规避/命令控制/外传/影响、OWASP 运行时与韧性优先级。
主要风险模式	非受控变更、漂移与退化、监控、追溯与问责不足、输出驱动的下流损害、滥用、欺诈与欺骗性操作、集中度与单一依赖风险。
主要控制目标	日志、证据与可调查性、独立测试与对抗性评估、韧性、回退与安全降级、变更控制与重新验证、运行时护栏、检测与响应、身份、凭据与委托治理。
证据重点	遥测设计、红队发现、事件手册、回滚测试记录、身份撤销记录、检测规则、事件复盘以及模型或代理行为基线。

9.12 标准映射

本章主要对齐 NIST AI RMF 的 MEASURE 和 MANAGE、NIST IR 8596、International AI Safety Report 2026 的风险管理和监测部分、NCSC 关于安全运行与维护的指南，以及 FSB 和 Bank of England 对监测、事件情报和监管可视性的关注。

9.13 相关场景画像

本领域在附录 B 中的所有场景画像里都会被进一步落地，重点对应面向客户的 AI、欺诈与调查辅助、合规与监测辅助、工作流代理以及高影响决策支持。

9.14 OWASP 威胁画像映射

OWASP 条目	纳入本章的原因	主要控制重点
无界消耗	覆盖在滥用需求或循环下出现的过度推理使用、失控成本、资源耗尽、侧信道探测和可用性退化。	速率与费用限制、上下文窗口控制、工作负载配额、异常检测以及快速限流或隔离。
级联失效	覆盖单一代理、工具、记忆或供应商故障向更广泛多代理或多系统破坏的传播。	影响半径控制、断路器、传播监测、回滚演练和跨代理血缘追踪。
人机信任利用	覆盖通过有说服力的输出、伪造理由、过度依赖以及对可审计人工动作的隐蔽影响来操纵用户。	人类在环校准、显式确认、来源展示、可疑交互上报和操作人员培训。
失控代理	覆盖行为偏离、有害自主性、寄生式或欺骗式运行，以及在代理生态中的受损后持续存在。	行为基线、身份证明、隔离、重新接入控制、紧急停止与撤销以及高保真取证日志。

10. 金融行业强化要求

本章为大型金融机构提供叠加层要求。它不替代前述章节，而是在客户损害、审慎性关切、行为风险、市场敏感性、监管问责、第三方集中度、委托权限和系统性影响要求更高标准时，对前述要求进行强化。

本强化层应从三层理解。第一，高影响使用原则 规定金融机构在哪些情形下宜默认采用更强审查、更窄自动化和更高证据标准。第二，金融脆弱性与场景强化 说明哪些常见 AI 风险会演变为审慎性、行为、市场或系统性关切。第三，控制与审计映射 说明机构应如何将这些关切连接到正文控制域、附录细则和审计证据。

10.1 面向客户的 AI

当面向客户的 AI 系统能够影响客户理解、产品选择、投诉处理、披露、适当性、欺诈响应或金融服务可得性时，组织宜默认将其视为高影响。对于重大事项，组织不得仅依赖生成输出决定最终客户结果，除非存在受控审查或边界明确的自动化逻辑。

10.2 授信、承保、定价、欺诈、反洗钱、合规、交易与监测

用于授信、承保、定价、欺诈检测、反洗钱、合规审查、交易支持、监测或其他具有重大后果的工作流中的 AI，应被治理为决策支持系统或受控自动化系统，而不是非正式生产力工具。其使用应在流程层面可解释、在决策层面可归因，并能被有资格的人类操作人员复核。

在本领域内，机构宜至少区分两类控制对象。客户结果型决策支持 包括授信、承保、定价、适当性及类似会直接影响客户待遇或审慎结果的决策。控制、调查与市场完整性支持 包括欺诈、反洗钱、合规、交易支持、监测和调查工作流，其中 AI 可能影响证据处理、升级、干预或市场行为。前者要求更强的可质疑性、结果测试和人工推翻标准；后者要求更强的证据完整性、对抗测试和升级纪律。

这些工作流中的 AI 安全治理还应与模型风险管理、操作风险、合规监督和信息安全治理显式衔接。当某一用例跨越这些控制域时，机构不应让责任归属保持模糊。

10.2.1 交易与市场完整性

与交易相关的 AI 使用宜至少区分四类控制区域：投研与市场分析、信号生成与建议、交易前控制支持 以及 执行或交易后监测支持。这些区域在权限、延迟敏感性、市场行为影响和可接受错误容忍度上存在实质差异，机构不宜将其作为单一同质用例统一治理。

对于交易和市场完整性用途，机构宜假设以下风险会被放大：模型行为相关性、对共享提供商或共享数据的隐性依赖、貌似有说服力但证据薄弱的市场叙事，以及运行时变更、工具滥用或监督不足对市场滥用、无序交易或错误执行的放大效应。因此，控制宜包括：受限执行权限、交易前风险闸门、建议输出与可执行动作的明确分离、市场敏感时段内更严格的变更纪律、对可能影响市场的信息进行多源校验，以及经测试的紧急暂停或停止机制。

当 AI 可能影响订单生成、路由、执行参数、市场监测或升级决策时，机构宜保留从输入和模型输出到人工批准、下游动作及交易后复核的全链路决策谱系。凡是可能影响市场行为的盘中模型、提示词、工具、连接器或策略变更，宜比普通生产力或分析类变更接受更严格的批准、可观测性和回滚要求。

10.2.2 交易场景风险、控制与证据矩阵

下表为常见交易相关 AI 场景提供最低控制视图。其目的在于区分权限和风险实质不同的控制区域，而不是将所有交易用途视为同一类别。

交易场景	主要风险重点	最低控制与证据要求
投研与市场分析	错误信息、来源薄弱、模型羊群化、对有说服力叙事的过度信任。	实施来源证明检查、对市场敏感信息进行多源校验、明确不可执行边界、对重大输出进行有资格的人工复核，并保留来源追踪、引用质量复核、分析师质疑记录、局限性披露以及研究输出不能直接触发交易的证据。
信号生成与建议	误报、不稳定信号、隐性提供商集中度、跨交易平台或跨模型的相关性行为。	实施挑战者复核、受限置信度处理、行动前审批边界、集中度识别与异常相关性测试，并保留信号验证记录、对比测试、审批边界设计、相关性行为测试结果以及提供商依赖记录。
交易前控制支持	控制绕过、提示或工具操纵、影响限额、路由或订单参数的不安全建议。	实施确定性风险闸门、建议路径与执行路径分离、参数校验、受限权限以及市场时段内更强复核，并保留从 AI 输出到交易前闸门的控制映射、拒绝案例样本、参数校验日志、盘中变更审批记录以及停止机制准备度测试。
执行与路由支持	过度委托权限、延迟敏感型失效、不安全盘中变更、级联执行效应。	实施严格受限的执行权限、对重大委托实施双人控制、实时可观测性、紧急暂停以及经过回滚测试的操作程序，并保留委托权限台账、执行边界记录、实时遥测、操作员接管日志、暂停测试结果以及事件后重建能力。
交易监测与市场滥用复核	漏检滥用模式、过度标记、证据污染、推理不可见、人工形式化批准。	实施证据谱系管理、复核阈值、更强解释质量、检测支持与执法行动分离以及分析师质疑要求，并保留告警处置轨迹、证据保留记录、解释质量复核、误报与漏报测试以及升级决策可追溯性。

10.3 第三方模型集中度

金融机构应识别因依赖少数模型提供商、云提供商、代理平台或关键数据集而产生的重大运营与系统性集中度风险。机构宜了解：若各项依赖发生故障、退出、退化或被攻破，哪些业务服务、控制职能和客户渠道将受到影响。

10.4 深度伪造与身份滥用

机构宜假设 AI 会提高社会工程、冒充、欺诈开户、支付诈骗和操纵尝试的规模与质量。因此，控制措施宜包括更强的身份校验、渠道验证、欺诈监测和客户通信防护，尤其是在语音、图像或文档真实性对运营具有关键意义的场景。

10.5 重大决策可追溯性

对于重大的客户、行为、审慎、市场或合规结果，机构应保留足够记录，以说明 AI 发挥了什么作用、使用了哪些数据或知识源、需要哪些批准、人工判断如何介入，以及最终决定是如何形成的。

10.6 人工接管

高影响金融 AI 系统应支持及时的人为接管、升级和服务回退。接管形式宜与运行模式相称。对于较慢速的决策支持或客户结果型工作流，这可能意味着在产生重大效果前实施决策级人工复核、撤销或受控批准。对于低时延的交易、监测、欺诈拦截、路由或类似工作流，人工接管则可以表现为系统级暂停、参数冻结、权限撤销、停止开关激活或受控回退，而不必要求逐动作的事前人工放行。组织不宜将 AI 可用性或 AI 判断作为执行关键监管、客户保护或市场完整性职能的唯一途径。

10.7 业务连续性与安全回滚

机构应定义并测试以下情形下如何维持运营：模型提供商失效、AI 控制功能被攻破、面向客户的 AI 变得不可靠，或监管质疑要求暂停或回滚。连续性规划应包括退化但合法且受控的人工或替代处理路径。

10.8 监管可辩护性

机构宜能够证明 AI 的使用是有意识规划、已完成分类、已被控制、已被监控且可被质疑的。如果机构无法解释为何使用某模型或代理、其拥有什么权限、输出如何被检查，以及客户和审慎性风险如何被限制，则该用例不宜被视为可用于重大生产活动。

对于重大活动，机构宜采用明确的保守默认立场。凡是缺乏重大决策可追溯性、缺乏经过测试的人工作业回退路径、委托权限或非人身份边界不清，或对第三方模型及平台的重大变更缺乏足够可见性的用例，均不宜被视为具备生产就绪性。

10.9 金融行业脆弱性主题

金融机构宜明确评估 AI 采用如何放大金融行业脆弱性，包括那些可能超出单一机构控制失效、进而演变为市场级或系统级影响的脆弱性。至少在判断某 AI 用例是否可进入生产环境时，机构宜评估以下脆弱性主题：

金融场景	主要脆弱性主题	控制重点
面向客户的 AI 服务	欺诈、冒充与虚假信息；与法律、监管和伦理边界错位；模型风险、数据质量与治理薄弱。	强化披露控制、可验证的升级路径、身份与渠道校验、针对重大客户影响的输出复核、投诉可追溯性以及回退至人工服务。
授信、承保与定价	模型风险、数据质量与治理薄弱；市场相关性与羊群效应；与法律、监管和伦理边界错位。	开展独立验证、偏差与公平性审查、决策可追溯性、挑战者模型或对比审查、受控权限边界，以及围绕行为和审慎目标的周期性结果测试。
欺诈、反洗钱、合规与调查	网络风险与 AI 使能的网络滥用；欺诈、冒充与虚假信息；第三方依赖；模型风险与治理薄弱。	强化证据处理、对重大行动设置人工决策关口、开展针对规避和提示操纵的对抗测试、控制外部情报来源，并保留可满足调查要求的日志。
交易、市场分析与监测	市场相关性与羊群效应；模型风险与治理薄弱；网络风险与 AI 使能滥用；虚假信息影响。	开展相关性行为测试、设置紧急停用机制、限制执行权限、对可能影响市场的信息进行多源校验、监测共享信号，并对异常同步行为实施更强升级机制。
企业生产力与知识助手	第三方依赖与服务提供商集中度；隐私放大效应；网络风险与 AI 使能滥用；虚假信息或幻觉传播。	实施数据分段、检索访问控制、内容真实性校验、连接系统最小权限、供应商尽调以及防止过度信任的员工操作指引。
AI 使能的软件开发与内部运营	网络风险与 AI 使能滥用；第三方依赖；模型与治理薄弱；长期结构性依赖。	实施代码与变更审查、秘密与凭证保护、沙箱隔离、依赖来源校验、生产隔离，以及针对供应商故障或大规模不安全输出的连续性演练。
依赖外部模型或云服务的核心控制职能	第三方依赖与服务提供商集中度；网络风险；模型风险；长期结构性影响。	开展集中度映射、合同透明度管理、退出与替代规划、韧性测试、服务关键性分级，并向董事会提供跨全机构依赖集中度可视性。
行业级或市场敏感型用例	市场相关性与羊群效应；欺诈与虚假信息；与市场完整性要求错位；长期结构性影响。	开展系统性外溢情景分析、制定协同事件处置手册、做好外部报告准备、进行市场完整性审查，并在相关性采用可能放大压力时设置更保守的部署阈值。

这些脆弱性主题意味着金融机构需要承担更强的控制期望，包括集中度映射、退出准备、在可行情况下保持多样性、开展相关性行为测试、监测欺诈与虚假信息、强化模型治理，以及为重大用途保留可满足监管审查要求的证据。

10.10 金融场景控制映射

金融机构应将每个重大 AI 用例映射到第 3-9 章的通用控制域、附录 B 的场景画像，以及附录 C-E 的详细参考矩阵。该映射的目的，是降低监管审查和内部审计难度：审查人员应能够看到业务场景由哪些控制域覆盖、适用哪些威胁框架，以及应存在什么证据。

该表宜作为金融强化层与本指引其余部分之间的主要运行桥梁使用。它回答的是：某一金融用例适用哪些章节控制，以及在将该用例视为重大生产活动之前，最低应具备哪些证据。

金融场景	主要适用章节控制	相关附录细节	最低审计证据
零售或私人银行客户助手	3, 4, 6, 9, 10	附录 B 客户聊天；附录 C LLM01、LLM02、LLM05、LLM09；附录 E 提示注入、收集和外传技术。	客户影响分类、批准话术边界、检索授权测试、投诉或升级记录、对话抽样审计。
投研、投顾或适当性支持	3, 4, 6, 9, 10	附录 B 摘要与高影响决策支持；附录 C LLM09；第 6 与 9 章中的可靠性与操纵控制。	来源证明、引用质量测试、人工复核记录、模型限制披露、决策理由追踪。
授信、承保、定价或额度建议	3, 4, 5, 6, 9, 10	附录 B 高影响决策支持；附录 C LLM04、LLM09；附录 E 模型操纵与影响技术。	模型治理记录、数据血缘、偏差和结果测试、人工推翻流程、不利行动解释支持、变更再验证。
欺诈、反洗钱、制裁或调查辅助	3, 4, 6, 7, 8, 9, 10	附录 B 欺诈与调查辅助；附录 D ASI02、ASI03、ASI09；附录 E 凭据访问、收集和外传技术。	调查员复核链、数据访问范围、告警处置记录、工具使用日志、误报和漏报复核、可疑交互升级。
交易、市场分析或监测	3, 5, 6, 7, 9, 10	附录 B 交易与执行支持；第 7 与 9 章中的运行时、可靠性和失控控制；附录 E 命令、外传和影响技术。	交易前后控制映射、延迟和可用性限制、盘中变更审批记录、人工批准边界、停止机制测试以及市场滥用监测证据。
软件工程或运营代理	5, 7, 8, 9, 10	附录 B 代码助手与高权限代理；附录 D ASI04、ASI05、ASI08、ASI10；附录 E 沙箱规避、逃逸到宿主机和机器攻陷技术。	代码仓库权限映射、代码审查记录、沙箱策略、依赖扫描、部署批准、回滚和撤销测试。
第三方模型或云托管 AI 平台	3, 5, 8, 9, 10	附录 A 参考映射；附录 C LLM03；附录 D ASI04；附录 E 供应链与依赖技术。	供应商尽调、集中度评估、退出计划、重大变更通知流程、独立验证、事件协作条款。
深伪、冒充或社会工程防御	3, 4, 6, 8, 9, 10	第 6、8 与 9 章中的身份滥用与合成内容控制；附录 D ASI09；附录 E 深伪、钓鱼、侦察和凭据技术。	身份核验规则、带外验证、深伪检测证据、员工培训、客户升级路径、欺诈损失监控。

10.11 标准映射

本强化章节主要对齐 FSB 2024，尤其是其第 4.2 节关于金融行业脆弱性的分析、FSB 2025 关于 AI 采用与相关脆弱性监测的方法、Bank of England 2025 关于 AI 相关系统性风险监测的框架、IOSCO CR/01/2025 关于资本市场 AI 用例与市场完整性风险的分析、FINMA Guidance 08/2024 关于使用 AI 时的治理与风险管理要求、OSFI Guideline E-23 关于涵盖 AI 或 ML 的模型风险管理要求，以及各国央行和监管机构强调的人类责任与风险导向监督。

10.12 相关场景画像

本强化章节在 附录 B 中进一步落地，尤其对应外部客户聊天与服务、欺诈与调查辅助、合规与监测辅助、交易与执行支持，以及授信、承保、定价等重大金融工作流程中的高影响决策支持。

附录 A. 参考标准映射

- 主要贡献：治理结构、生命周期框架、可信特征，以及 GOVERN、MAP、MEASURE、MANAGE 四大功能。
- 主要贡献：AI 与网络安全交叉域、保护 AI、使用 AI 增强防御，以及抵御 AI 赋能攻击的重点领域。
- 主要贡献：面向 AI 使能系统的对抗技术和威胁链视角。
- 主要贡献：系统要素框架、威胁驱动的安全控制思维，以及残余风险意识。
- 主要贡献：应用层攻击面，包括提示注入、敏感信息披露、供应链、投毒、不安全输出处理、过度代理、向量弱点、错误信息和无界消耗。
- 主要贡献：目标驱动、使用工具、具备自主或半自主能力的代理系统的特有风险。
- 主要贡献：新兴风险、代理、恶意使用、可靠性挑战、失控问题、技术护栏和监测主题。
- 主要贡献：组织层面的 AI 管理体系要求。
- 主要贡献：AI 特定风险管理指导，以及其纳入组织风险流程的方法。

1	主要贡献：安全设计、安全开发、安全部署，以及安全运行与维护。
2	
3	主要贡献：对外部开发或集成 AI 系统的安全部署要求。
4	
5	主要贡献：面向自建 AI 环境的经过验证的 AI Factory 架构与部署模式，包括基础设施分离、生命周期控制和运行设计。
6	
7	主要贡献：面向 AI 的高性能 Ethernet fabric 设计，包括其对分段隔离、东西向流量行为和基础设施可观测性的启示。
8	
9	主要贡献：DPU 信任边界设计、主机隔离模式、所有权分离，以及基础设施控制平面安全。
10	
11	主要贡献：用于东西向流量和高速数据平面监测的独立基础设施遥测与基于 DPU 的威胁检测。
12	
13	主要贡献：AI Factory 环境的安全架构模式，包括零信任分段、运行控制和敏感工作负载保护。
14	
15	主要贡献：面向高价值 AI 工作负载的机密计算、证明、使用中数据保护以及 GPU 平台安全能力。
16	
17	主要贡献：金融稳定脆弱性，包括集中度、网络风险、市场相关性、欺诈和模型风险。
18	
19	主要贡献：系统性风险监测视角、事件情报需求，以及集中度和监管可观测性主题。
20	
21	主要贡献：金融行业 AI 采用的司法辖区级监测方法、指标、数据缺口以及集中度监测考量。
22	
23	主要贡献：资本市场中的 AI 用例、交易与监测风险、市场完整性关切，以及证券市场中的治理期望。
24	
25	主要贡献：金融机构的 AI 治理、AI 台账与风险分类、数据质量、测试与持续监测、可解释性以及独立复核。
26	
27	主要贡献：明确延伸至金融机构 AI 和机器学习模型的模型风险管理监管期望。

A.1 交叉映射矩阵

下表提供参考来源与本指引结构之间的主要映射。它并不表示每个来源都适用于每一章，而是说明在派生政策要求、控制基线、评估问题、测试计划或审计证据时，应优先在哪些章节使用相应来源。

--	--	--	--

参考来源	指引主要位置	主要风险或控制贡献	证据与保证用途
NIST AI RMF 1.0	Chapters 1, 2, 3, 9; Appendix A	可信 AI 特征、治理、映射、度量、管理，以及 AI 与传统软件风险差异。	用于管理体系证据、风险框架、影响分级和复审节奏。
NIST IR 8596 Cyber AI Profile	Chapters 2, 5, 6, 7, 8, 9	保护 AI 系统、使用 AI 增强防御、抵御 AI 使能威胁。	用于网络控制覆盖、威胁驱动的安全运营和 AI 特定检测范围。
MITRE ATLAS	Chapters 2, 5, 6, 7, 8, 9; Appendix E	对手生命周期、具体 AI 攻击技术和已列出的缓解措施。	用于红队场景、检测工程、事件手册和技术到控制的可追溯性。
MITRE SAFE-AI	Chapters 2, 5, 6, 7, 8; Appendix B	系统要素框架、威胁驱动控制和残余风险处理。	用于场景画像设计和残余风险复核。
OWASP Top 10 for LLM Applications 2025	Chapters 2, 4, 5, 6, 7, 9; Appendix C	LLM 应用层脆弱性和预防指导。	用于应用安全测试、提示和输出控制、RAG 测试和运行时滥用检查。
OWASP Top 10 for Agentic Applications 2026	Chapters 2, 5, 7, 8, 9; Appendix D	代理式威胁、最小代理、工具使用、身份、记忆、代理间通信和失控代理问题。	用于代理审批、工具权限测试、沙箱证据和可观测性要求。
International AI Safety Report 2026	Chapters 2, 7, 9, 10	新兴 AI 风险、恶意使用、可靠性、失控、代理和风险管理约束。	用于新兴风险评审、压力场景和控制局限性分析。
ISO/IEC 42001	Chapters 1, 3; Appendix A	组织层 AI 管理体系期望。	用于政策治理、问责和管理体系审计证据。
ISO/IEC 23894	Chapters 2, 3, 9; Appendix A	AI 风险管理流程及其纳入组织风险管理的方法。	用于风险评估方法和生命周期风险复核。
NVIDIA Enterprise AI Factory Validated Design	Chapters 8, 9; Appendix B	面向自建 AI Factory 的经过验证的部署模式，包括基础设施布局、分离和运行设计。	用于架构基线、集群设计评审以及自建 AI 基础设施控制的证据期望。
NVIDIA Spectrum-X Ethernet	Chapters 8, 9; Appendix B	与 AI 集群中的东西向流量行为、可观测性和分段隔离相关的高性能 Ethernet fabric 特征。	用于 AI 集群中的 fabric 分段评审、遥测设计和网络路径控制验证。
BlueField Modes of Operation	Chapters 8, 9; Appendix B	DPU 信任边界与所有权分离模式，用于基础设施隔离和控制平面安全。	用于 DPU 运行模式决策、主机隔离评审和控制平面强化证据。
DOCA Argus Service Guide	Chapters 8, 9; Appendix B	用于东西向流量和高速基础设施路径的独立 DPU 遥测与威胁检测。	用于 AI fabric 的遥测架构、检测工程和独立监测证据。
NVIDIA AI Factory for Government - Security	Chapters 8, 9; Appendix B	AI Factory 环境的安全架构模式，包括分段隔离、运行治理和敏感工作负载保护。	用于 secure-by-design 集群架构评审、运行控制设计和高保证部署证据。
NVIDIA Secure AI with Blackwell and Hopper GPUs	Chapters 5, 8, 9; Appendix B	面向高价值 AI 工作负载的 GPU 平台安全、机密计算、证明和使用中数据保护。	用于高影响 AI 环境中的证明策略、机密工作负载设计和平台安全证据。

FSB 2024 AI in finance	Chapter 10 ; Appendix A	金融稳定脆弱性、集中度、网络风险、市场相关性、欺诈和模型风险。	用于金融行业强化、系统性风险分析和监管证据。
Bank of England 2025 AI in the financial system	Chapters 9 , 10 ; Appendix A	系统性监测、事件情报、集中度和监管可观测性。	用于监测策略、事件情报和金融行业韧性证据。
FSB 2025 AI monitoring	Chapters 9 , 10 ; Appendix A	AI 采用与相关脆弱性的监测方法、代理指标、数据缺口以及集中度监测考量。	用于行业监测设计、指标选择、集中度监测和监管报告准备。
IOSCO CR/01/2025 Artificial Intelligence in Capital Markets	Chapter 10 ; Appendices A , B	资本市场 AI 用例、市场完整性风险、交易与监测关切，以及证券市场中的治理期望。	用于交易、市场分析、监测和投资者保护控制设计及证据复核。
FINMA Guidance 08/2024	Chapters 3 , 4 , 9 , 10 ; Appendix A	金融机构使用 AI 时的治理、AI 台账与分类、数据质量、测试、监测、文档、可解释性和独立复核。	用于金融行业治理证据、AI 台账要求和监管式复核标准。
OSFI Guideline E-23 Model Risk Management	Chapters 3 , 5 , 10 ; Appendix A	延伸至 AI 或 ML 的模型风险管理期望，包括治理、验证、生命周期控制和监管问责。	用于高影响模型治理、独立验证和重大决策支持控制期望。

附录 B. 场景风险与控制细则

本附录以更具场景感的方式补充正文，其写法参考了 MITRE SAFE-AI 的实务导向风格以及 OWASP LLM 和 Agentic 应用指南中的具体攻击类别。这些场景画像并不替代前文的抽象风险模式模型，而是说明抽象风险模式和控制目标应如何落到典型企业实现中。

B.1 内部知识助手

字段	说明
场景说明	员工面向的知识助手从内部政策、流程、工程文档或业务知识中检索内容并回答问题。
典型架构形态	聊天界面、身份层、检索服务、知识库或向量库、托管或自托管模型、审计日志。
主要风险模式	敏感信息暴露、信任边界穿透、模型或上下文被操纵、输出驱动的下游损害。
代表性威胁与失效方式	检索范围过宽返回机密材料、隐藏系统指令暴露、恶意文档注入指令、日志保留敏感提示和答案、生成结果被误当作权威政策。
最低控制要求	在源系统执行授权、按受众和敏感度分隔语料、标记引用与生成内容、净化导入材料和附件、复用前验证输出。
高影响场景强化要求	对于法务、人力、财务或受监管政策内容，要求已验证引用、更严格检索范围，以及对具有操作约束力的回答进行人工复核。
证据与测试重点	重点测试文档型提示注入、通过检索实现的授权绕过，以及通过日志或引用造成的泄露。
标准映射	与 OWASP 关于提示注入和敏感披露的主题，以及 SAFE-AI 对数据和模型上下文的关注高度相关。

B.2 外部客户聊天与客服

字段	说明
场景说明	面向客户的助手回答产品、账户、服务或支持问题，并可能引导客户完成服务流程。
典型架构形态	公共聊天界面、客户身份或会话上下文、产品知识库、CRM 或服务 API、合规话术约束、监控。
主要风险模式	输出驱动的下游损害、敏感信息暴露、滥用、欺诈与欺骗性操作、权限放大与越权行动。
代表性威胁与失效方式	误导性产品解释、未授权客户数据披露、冒充、社会工程、未经授权承诺、从聊天直接升级到账户操作。
最低控制要求	将信息回复与交易性行动分离、保证会话完整性、按业务必要性限制客户数据访问、对受监管沟通使用批准话术、记录重大交互。
高影响场景强化要求	涉及客户结果、投诉处理结果或重大披露的内容，宜要求人工复核或严格边界的确定性规则。
证据与测试重点	重点测试误导性建议、数据过度暴露、通过客户输入进行的提示注入、冒充行为，以及从聊天到行动的不安全切换。
标准映射	与 OWASP 关于错误信息、提示注入、敏感披露和过度代理的主题高度相关，并与金融行业客户保护直接相关。

B.3 RAG 文档问答

字段	说明
场景说明	用户以自然语言提问，系统检索企业文档以支撑回答。
典型架构形态	检索流水线、嵌入模型、向量数据库、重排或过滤层、响应生成器、引用层、源文档仓库。
主要风险模式	模型或上下文被操纵、敏感信息暴露、供应链与来源不透明、输出驱动的下游损害。
代表性威胁与失效方式	检索投毒、文档中的隐藏指令、嵌入或向量治理薄弱、未授权语料混合、低质量检索导致虚假确定性。
最低控制要求	控制谁可新增或修改源材料、按信任级别和敏感度分隔语料、验证来源、约束检索文本进入提示的方式、清晰展示引用。
高影响场景强化要求	对影响运营、法律或客户结果的场景，使用更严格的检索审查、更小且更可信的语料，以及更高的拒答阈值。
证据与测试重点	重点测试语料投毒、引用完整性、跨人群未授权检索，以及向量库或嵌入弱点。
标准映射	与 OWASP 关于向量和嵌入弱点、提示注入、数据投毒，以及 MITRE 关于数据和模型操纵的关注高度相关。

B.4 代码助手与开发代理

字段	说明
场景说明	AI 通过生成代码、审阅变更、回答技术问题或执行有限开发动作来辅助开发人员。
典型架构形态	IDE 插件或 Web 助手、代码仓库访问、依赖知识、CI 或工单集成、可选代码执行或补丁能力。
主要风险模式	供应链与来源不透明、权限放大与越权行动、模型或上下文被操纵、敏感信息暴露。
代表性威胁与失效方式	虚构依赖名称引入恶意包、不安全代码建议、专有代码或密钥暴露、通过代码仓库内容进行提示注入，以及代理在审查不足下修改代码或基础设施。
最低控制要求	对代码变更强制人工审查、限制仓库和 CI 权限、扫描生成代码和依赖变更、隔离代码执行、避免在上下文窗口中暴露大范围密钥。
高影响场景强化要求	涉及生产配置、认证、密码学、支付、市场系统或客户数据处理的代码，应要求更强审查和确定性验证。
证据与测试重点	重点测试恶意依赖注入、代码仓库提示注入、密钥泄露、不安全自动修复行为以及代码执行边界。
标准映射	与 OWASP 关于供应链、提示注入和过度代理的主题高度相关，也体现 SAFE-AI 对供应链和残余风险的考虑。

B.5 办公自动化代理

字段	说明
场景说明	代理读取邮件、工单、日历或任务系统，并提出或执行常规工作流步骤。
典型架构形态	消息或办公系统集成、任务 API、工作流引擎、策略层、行动审计轨迹。
主要风险模式	权限放大与越权行动、信任边界穿透、输出驱动的下游损害、滥用、欺诈与欺骗性操作。
代表性威胁与失效方式	代理转发敏感信息、批准错误事项、执行伪造指令、通过任务串联升级权限，或根据模糊提示执行不可逆操作。
最低控制要求	使用任务特定权限、对写入或批准动作设置审批关口、验证可信发送方、限制记忆范围，并在可行时支持行动记录与回滚。
高影响场景强化要求	如果流程步骤影响财务、人力、访问控制、合同或外部沟通，应要求更强的人类授权和更窄的确定性行动模板。
证据与测试重点	重点测试伪造请求、通过邮件或工单进行的间接提示注入、不安全动作串联、审批绕过和回滚失败。
标准映射	与 OWASP 关于过度代理和不安全输出处理的主题高度相关，也体现 MITRE ATLAS 关于任务串联和运营影响的思路。

B.6 具备工具调用能力的高权限代理

字段	说明
场景说明	AI 代理能够浏览网页、调用 API、运行脚本、访问敏感仓库，或以提升权限修改系统。
典型架构形态	代理规划器、工具注册表、执行包装层、作用域凭据、沙箱、策略决策层、行动日志。
主要风险模式	权限放大与越权行动、信任边界穿透、模型或上下文被操纵、输出驱动的下游损害、敏感信息暴露。
代表性威胁与失效方式	提示注入触发任意 API 调用、代理将不可信网页内容视作指令、工具输出污染规划、Shell 或代码执行造成不可逆破坏、宽泛令牌暴露高价值系统。
最低控制要求	使用显式工具白名单、严格作用域凭据、沙箱执行、执行前策略中介、对重大行动的审批，以及快速撤销能力。
高影响场景强化要求	在生产中，不应允许开放式高权限执行，除非具备强隔离、受监控护栏和经过测试的紧急停用能力。
证据与测试重点	重点测试目标劫持、提示注入、工具滥用、Shell 或 API 滥用、不安全的长链规划以及凭据越权。
标准映射	与 OWASP 代理应用风险、OWASP 过度代理主题，以及 MITRE 针对工具使用和控制边界的对抗技术最为相关。

B.7 文档摘要与内容生成

字段	说明
场景说明	系统对文档进行摘要、起草报告、生成沟通材料，或为内部或外部用途生产叙述性内容。
典型架构形态	用户界面或批处理、模型调用、可选文档导入、可选源检索、策略检查、发布流程。
主要风险模式	输出驱动的下游损害、敏感信息暴露、模型或上下文被操纵、滥用、欺诈与欺骗性操作。
代表性威胁与失效方式	虚构事实、遗漏关键限制条件、泄露隐藏或源内容、公开沟通不符合政策、生成内容被误当作已验证分析。
最低控制要求	标记生成内容、对重大用途进行事实或来源复核、将起草与批准分离、限制对敏感输出进行再训练，并纳入披露与沟通治理。
高影响场景强化要求	面向投资者、监管、法务或客户的沟通应要求更强审查、版本控制和已留痕的批准责任。
证据与测试重点	重点测试无依据陈述、隐藏内容泄露、风格或政策违规，以及绕过人工审核的发布流程。
标准映射	与 OWASP 关于错误信息、不安全输出处理和敏感信息披露的主题高度相关。

B.8 欺诈与调查辅助

字段	说明
场景说明	AI 协助分析师进行欺诈检测、告警分流、案件摘要和调查推理。
典型架构形态	案件管理数据、交易数据、告警流、分析师界面、对既往案件的可选检索、调查工作流集成。
主要风险模式	敏感信息暴露、输出驱动的下游损害、模型或上下文被操纵、滥用、欺诈与欺骗性操作。
代表性威胁与失效方式	敏感案件材料泄露、AI 生成推理置信度虚高、对手塑造输入以逃避检测、摘要遗漏减责事实、分析师过度依赖生成建议。
最低控制要求	限制案件数据访问、保留源证据、将建议与最终处置分离、监测滥用与查询模式，并培训分析师理解 AI 局限。
高影响场景强化要求	影响客户资金、账户限制、对外报告或执法联系的行动，应要求人工问责和留痕的证据审查。
证据与测试重点	重点测试对抗性规避、案件摘要泄露、无依据结论，以及不安全的升级或结案决策。
标准映射	与 NIST IR 8596 中 AI 赋能防御和滥用主题高度相关，也与金融行业中的欺诈和客户损害关切密切相关。

B.9 合规与监测辅助

字段	说明
场景说明	AI 协助开展合规审查、通信监测、政策映射、控制测试支持或监管问题分流。
典型架构形态	政策与流程语料、通信数据、案件工作流工具、分析师审查界面、证据保留机制。
主要风险模式	敏感信息暴露、输出驱动的下游损害、监控、追溯与问责不足、滥用、欺诈与欺骗性操作。
代表性威胁与失效方式	AI 漏掉政策违规、过度标记正常活动、泄露监测内容、给出无法支撑监管审查的浅层理由，或模糊控制结论的来源依据。
最低控制要求	保留证据谱系、记录审查阈值、将分析师判断与 AI 建议分离、维持可辩护的保留和访问规则，并同时测试漏检与误报。
高影响场景强化要求	若输出可能影响监管报送、纪律处分或市场行为评估，应要求更强可复核性、更严格证据留存和更有限的自动化。
证据与测试重点	重点测试解释质量、证据保留、泄露、决策可追溯性，以及人工审查者是否能有效质疑 AI 生成理由。
标准映射	与 NIST AI RMF 关于可追溯性和问责性的目标高度相关，也与金融强化章节中的客户和市场完整性关注点密切相关。

B.10 高影响决策支持

字段	说明
场景说明	AI 为授信、承保、定价、资格判断、优先级排序、例外处理或其他对客户、财务或法律义务具有重大影响的决策提供支持。
典型架构形态	结构化与非结构化输入、可选文档导入、模型评分或生成式推理、分析师或审批人界面、最终决策工作流。
主要风险模式	输出驱动的下游损害、 监控、追溯与问责不足、 模型或上下文被操纵、 敏感信息暴露、 集中度与单一依赖风险。
代表性威胁与失效方式	无依据或不稳定的建议、AI 推理难以被质疑、静默模型漂移、由上下文变化引发的不一致处理，以及在重大决策上对单一提供商或模型的过度依赖。
最低控制要求	除非经过正式批准的边界自动化，否则将 AI 视为决策支持；保留决策输入和审查记录；要求受过训练的人类监督；定义拒绝、升级和人工推翻标准；监测决策后结果。
高影响场景强化要求	对重大客户或审慎性结果，应要求更强的部署前验证、更严格的变更控制、更保守的回退机制，以及更高的审计和监管证据标准。
证据与测试重点	重点测试真实案例下的稳定性、对抗性输入塑形、解释质量、审查者人工推翻行为，以及提供商替换或中断情景。
标准映射	与 NIST AI RMF、ISO/IEC 23894、FSB 2024 以及 Bank of England 2025 关于重大结果、治理和集中度的关切高度相关。

B.11 交易与执行支持

字段	说明
场景说明	AI 在面向市场的工作流中支持市场分析、交易想法、信号复核、交易前控制检查、执行参数支持、交易监测或交易后例外复核。
典型架构形态	市场数据流、研究或新闻导入、模型或代理分析层、交易员或分析师界面、可选的订单管理或监测工具、审批关口以及可观测性管道。
主要风险模式	输出驱动的下游损害、 模型或上下文被操纵、 权限放大与越权行动、 人机信任利用、过度依赖与权威扭曲、 集中度与单一依赖风险。
代表性威胁与失效方式	AI 夸大市场信号质量、传播虚假或来源薄弱的市场敏感信息、促成跨交易台或机构的相关性行为、通过工具滥用绕过交易前护栏，或引入影响执行或监测质量的不安全盘中变更。
最低控制要求	将研究或建议输出与可执行动作分离；对路由或执行支持施加受限权限；保留来源证明和审批谱系；实施交易前闸门和交易后复核；定义盘中变更限制及经测试的停止机制。
高影响场景强化要求	凡是 AI 可能影响订单生成、路由、执行参数或市场滥用升级的场景，应要求更强人工问责、更严格运行时可观测性、更保守部署阈值，以及对市场敏感信息进行多源校验。
证据与测试重点	重点测试相关性行为场景、提示或上下文操纵、市场新闻校验失效、交易前控制绕过、不安全盘中变更、操作人员人工推翻质量以及紧急暂停准备度。
标准映射	与 FSB 2024 和 2025、IOSCO CR/01/2025、Bank of England 2025 以及金融行业关于集中度、市场完整性、系统性相关性和监管可观测性的主题高度相关。

B.12 自建 AI Factory 与 GPU 集群

字段	说明
场景说明	组织部署并运行自建 AI Factory、DGX 或 HGX 集群、GPU 云，或类似的加速计算环境，用于模型训练、微调、大规模推理或共享 AI 平台服务。
典型架构形态	GPU 服务器、加速器互联、高速计算 fabric、存储 fabric、DPU 或 SmartNIC 层、调度器或编排器、集群管理器、固件与镜像生命周期工具、监控栈，以及带内与带外管理平面。
主要风险模式	信任边界穿透、权限放大与越权行动、敏感信息暴露、供应链与来源不透明、资源耗尽、成本滥用与可用性退化、集中度与单一依赖风险。
代表性威胁与失效方式	调度器控制薄弱导致未授权工作负载落位；扁平化东西向 fabric 允许横向移动；RDMA 或 GPUDirect 路径在缺乏显式策略下跨越信任边界；固件或驱动篡改破坏平台信任；存储命名空间在租户间串扰；集群管理或 DPU 控制平面权限过宽或监测不足；高强度作业耗尽共享基础设施并拖垮关键工作负载。
最低控制要求	分离计算网、存储网、带内管理网和带外管理网；强化调度器与集群控制角色；对 RDMA 和直接内存路径实施显式治理；使用受控的固件、驱动和镜像基线；隔离租户与存储命名空间；保留来自计算、网络、DPU 和存储层的独立遥测；定义并测试遏制与工作负载暂停程序。
高影响场景强化要求	对于受监管、多租户、安全敏感或高价值模型环境，应要求更强的证明能力、更严格的变更控制、更窄的管理权限、经过验证的参考架构、分阶段固件更新、更保守的工作负载共租策略，以及不单纯依赖受影响主机的紧急隔离路径。
证据与测试重点	重点测试调度器滥用、控制平面权限提升、固件或镜像来源失效、fabric 或存储层的租户隔离失效、RDMA 或直接内存路径滥用、东西向横向移动、遥测盲区，以及在敌对或失控工作负载下的集群级韧性。
标准映射	与 NIST IR 8596 和 SAFE-AI 中关于 AI 基础设施与运行的关切高度相关，并在运行实践上吸收 NVIDIA Enterprise AI Factory Validated Design 、NVIDIA Spectrum-X Ethernet 、BlueField Modes of Operation 、DOCA Argus Service Guide 、NVIDIA AI Factory for Government - Security 以及 NVIDIA Secure AI with Blackwell and Hopper GPUs 的指导。

附录 C. OWASP Top 10 for LLM Applications 映射

本附录将 OWASP Top 10 for LLM Applications 2025 映射到本指引的规范化风险模式、控制目标和控制域章节中。它用于补充而不是替代第 2 章中的分类体系。

在实施、评审和审计时，每一行都宜结合第 4-10 章中相关的 Threat-Informed Deep Dive 和 Coverage Mapping 一并阅读。通常应保留的证据包括设计控制、测试用例、运行时可观测性、例外处理，以及说明相关风险是否被缓解、承受或排除在范围之外的记录。

OWASP LLM 条目	核心关注点	主要风险模式映射	主要控制目标映射	主要章节映射
提示注入	不可信输入、检索内容或隐藏指令改变模型行为或应用控制流。	信任边界穿透、模型或上下文被操纵、输出驱动的下游损害。	边界校验与上下文隔离、独立测试与对抗性评估、运行时护栏、检测与响应。	6, 7, 9
敏感信息披露	敏感信息通过输出、上下文窗口、日志、记忆或检索泄露。	敏感信息暴露、信任边界穿透。	数据最小化与保密保护、边界校验与上下文隔离、日志、证据与可调查性。	4, 6, 7, 8
供应链	上游模型、库、适配器、提供商和仓库带来隐蔽依赖风险。	供应链与来源不透明、集中度与单一依赖风险、模型或上下文被操纵。	来源、完整性与依赖保证、第三方与集中度风险管理、变更控制与重新验证。	5, 8, 10
数据与模型投毒	训练、微调、评估或检索输入被投毒，从而改变行为或植入不安全潜在效果。	模型或上下文被操纵、供应链与来源不透明、非受控变更、漂移与退化。	来源、完整性与依赖保证、变更控制与重新验证、独立测试与对抗性评估。	5, 6, 9
不当输出处理	生成输出在下游系统中被不安全地执行、渲染或信任。	输出驱动的下游损害、权限放大与越权行动、信任边界穿透。	边界校验与上下文隔离、人工授权与可逆性、运行时护栏、检测与响应。	6, 7, 9
过度代理能力	模型或代理获得过大的权限、过多工具或过强下游行动能力。	权限放大与越权行动、输出驱动的下游损害、滥用、欺诈与欺骗性操作。	最小权限与分段隔离、人工授权与可逆性、运行时护栏、检测与响应。	7, 8, 9
系统提示泄露	隐藏提示、策略或密钥被暴露，或被误当作持久安全控制。	敏感信息暴露、信任边界穿透、模型或上下文被操纵。	数据最小化与保密保护、边界校验与上下文隔离、来源、完整性与依赖保证。	4, 6, 8
向量与嵌入弱点	薄弱的 RAG、嵌入或向量库控制导致投毒、泄露或跨租户串扰。	模型或上下文被操纵、敏感信息暴露、信任边界穿透。	边界校验与上下文隔离、数据最小化与保密保护、来源、完整性与依赖保证。	4, 6, 7
错误信息	貌似可信但错误的输出误导用户、操作人员或下游系统。	输出驱动的下游损害、滥用、欺诈与欺骗性操作、监控、追溯与问责不足。	人工授权与可逆性、日志、证据与可调查性、独立测试与对抗性评估。	6, 9, 10
无界消耗	过度推理使用、失控循环、成本暴涨、资源耗尽和可用性退化。	资源耗尽、成本滥用与可用性退化、集中度与单一依赖风险。	运行时护栏、检测与响应、韧性、回退与安全降级、最小权限与分段隔离。	7, 8, 9

附录 D. OWASP Top 10 for Agentic Applications 映射

本附录将 OWASP Top 10 for Agentic Applications 2026 映射到本指引的规范化风险模式、控制目标和控制域章节中。它用于补充而不是替代第 2 章中的分类体系。

在实施、评审和审计时，每一行都宜结合第 7-9 章中的相关内容一并阅读；当代理可能影响客户、市场、监管、运营或支付结果时，还应结合第 10 章金融强化要求。通常应保留的证据包括代理身份设计、工具权限映射、记忆与上下文控制、可观测性设计、审批记录，以及经过测试的遏制或撤销路径。

OWASP 代理式 条目	核心关注点	主要风险模式映射	主要控制目标映射	主 要 章 节 映 射
代理目标劫持	输入、工件或同伴内容改变代理的目标、规划或行动选择。	模型或上下文被操纵、信任边界穿透、输出驱动的下游损害。	边界校验与上下文隔离、人工授权与可逆性、运行时护栏、检测与响应。	6, 7, 9
工具滥用与利用	代理在既有权限范围内不安全地、过度地或错误地使用合法工具。	权限放大与越权行动、输出驱动的下游损害、资源耗尽、成本滥用与可用性退化。	最小权限与分段隔离、运行时护栏、检测与响应、日志、证据与可调查性。	7, 8, 9
身份与权限滥用	委派链、凭据继承和薄弱的非人身份治理被滥用以升级访问。	权限放大与越权行动、信任边界穿透、敏感信息暴露。	最小权限与分段隔离、治理与责任归属、运行时护栏、检测与响应。	3, 7, 8, 10
代理式供应链脆弱性	代理框架、工具描述符、编排组件和依赖项被攻破或被操纵。	供应链与来源不透明、模型或上下文被操纵、集中度与单一依赖风险。	来源、完整性与依赖保证、第三方与集中度风险管理、变更控制与重新验证。	5, 7, 8
意外代码执行	代理或其连接工具以不安全或受攻击者影响的方式执行代码、Shell命令或解释器。	权限放大与越权行动、信任边界穿透、输出驱动的下游损害。	最小权限与分段隔离、运行时护栏、检测与响应、韧性、回退与安全降级。	7, 8, 9
记忆与上下文投毒	持久记忆、可检索上下文或共享代理状态被投毒，并在后续驱动不安全决策或行动。	模型或上下文被操纵、敏感信息暴露、非受控变更、漂移与退化。	边界校验与上下文隔离、变更控制与重新验证、运行时护栏、检测与响应。	4, 6, 7, 9
不安全的代理间通信	代理之间的消息可能被伪造、篡改、重放、拦截或在语义层被操纵。	信任边界穿透、权限放大与越权行动、敏感信息暴露。	最小权限与分段隔离、边界校验与上下文隔离、日志、证据与可调查性。	7, 8, 9
级联失效	单一代理、工具、供应商或记忆路径中的故障或受损向更广泛破坏传播。	非受控变更、漂移与退化、资源耗尽、成本滥用与可用性退化、监控、追溯与问责不足。	韧性、回退与安全降级、运行时护栏、检测与响应、日志、证据与可调查性。	7, 8, 9, 10
人机信任利用	用户因代理具有说服力、拟人化或虚假权威感而被操纵，从而批准不安全行动或披露数据。	滥用、欺诈与欺骗性操作、输出驱动的下游损害、监控、追溯与问责不足。	人工授权与可逆性、日志、证据与可调查性、运行时护栏、检测与响应。	6, 7, 9, 10
失控代理	受损或行为偏离的代理在多代理或人机生态中持续存在、实施欺骗或有害行动。	非受控变更、漂移与退化、滥用、欺诈与欺骗性操作、监控、追溯与问责不足。	治理与责任归属、运行时护栏、检测与响应、韧性、回退与安全降级。	7, 8, 9, 10

附录 E. MITRE ATLAS 攻击技术与缓解控制矩阵

E.1 目的与使用方式

本附录将选定的 MITRE ATLAS 战术、重点技术和重点缓解措施映射到本指引的控制语言中。它用于补充而不是替代第 2 章中的分类体系，以及第 3-10 章中的控制域要求。

下表依据截至 2026-05-27 的 MITRE ATLAS 官方数据源生成，覆盖 16 个战术、170 条技术和 35 条缓解措施。若当前 ATLAS 数据未将某条 technique 直接关联到 mitigation，本附录会显式标注“未列出直接 mitigation”。若某些子技术在当前数据中未单独携带 tactic 字段，则其 tactic 上下文按父技术推导，并在表中明确标识。

各战术下的技术计数反映的是当前数据模型中的战术关联数，而不是互斥的唯一总数。因此，同一条技术可能在多个战术下被重复计入。

在实施、评审和审计时，附录 E 宜作为威胁驱动力的测试、检测和控制映射参考使用。指引控制重点 与 指引控制对应关系 两列将所选技术和缓解措施映射到本文件的控制语言，以便安全团队将对手技术与章节级要求和证据期望连接起来。

E.2 攻击生命周期概览

战术编号	战术名称	技术数量	安全解释
AML.TA0002	Reconnaissance	12	与 AI 系统相关的情报收集与目标理解。
AML.TA0003	Resource Development	26	为后续 AI 攻击行动准备能力、基础设施、工具和工件。
AML.TA0004	Initial Access	15	获得对 AI 环境、工作流或相连业务流程的初始立足点。
AML.TA0000	AI Model Access	4	获得对模型、模型接口或模型邻接交互路径的访问。
AML.TA0005	Execution	13	执行可驱动 AI 系统行为的代码、提示、输入或操纵。
AML.TA0006	Persistence	14	在 AI 资产、状态或工作流上维持持续存在或持久影响。
AML.TA0012	Privilege Escalation	4	在 AI 技术栈或关联系统中扩大权限或控制范围。
AML.TA0007	Defense Evasion	16	规避围绕 AI 系统的保护措施、监控、策略检查或检测逻辑。
AML.TA0013	Credential Access	6	获取会暴露 AI 系统或邻接环境的凭据、密钥或令牌。
AML.TA0008	Discovery	16	了解运行时状态、模型行为、策略、资产和可达路径。
AML.TA0015	Lateral Movement	5	在相互连接的 AI 或企业组件之间横向移动。
AML.TA0009	Collection	6	从 AI 系统或邻接流程中收集有价值的数据、工件或输出。
AML.TA0001	AI Attack Staging	17	专门为利用 AI 而准备或塑造攻击输入、工件或攻击序列。
AML.TA0014	Command and Control	3	在 AI 使能的入侵链中维持远程影响、控制或信号传递。
AML.TA0010	Exfiltration	9	将敏感输出、模型、数据或其他高价值工件移出环境。
AML.TA0011	Impact	19	通过 AI 受损或滥用造成运营、安全、财务或信任损害。

E.3 优先攻击技术矩阵

完整的 ATLAS 数据集对于专业威胁狩猎仍然有价值，但在主 Guidance 中逐条复写所有技术，会显著增加篇幅而未必成比例提高大多数读者的决策价值。因此，本节保留一份更适合企业 AI、LLM 应用、代理式系统和金融行业部署的优先技术矩阵。

如需穷尽性技术覆盖，团队宜结合第 5-10 章控制映射，直接查阅 MITRE ATLAS 官方数据集。

技术编号	技术名称	在此处的重要性	指引控制重点
AML.T0000	Search Open Technical Databases	公开技术披露可能提升对手对已部署模型、提示、数据和配套控制的理解。	数据最小化与保密保护、边界校验与上下文隔离、日志、证据与可调查性。
AML.T0002	Acquire Public AI Artifacts	可公开获取的模型和数据集工件会加速定向攻击、复制和后续滥用准备。	来源、完整性与依赖保证、第三方与集中度风险管理、变更控制与重新验证。
AML.T0005	Create Proxy AI Model	代理模型构建与模型抽取、安全绕过、攻击演练和能力复制相关。	数据最小化与保密保护、运行时护栏、检测与响应、日志、证据与可调查性。
AML.T0102	Generate Malicious Commands	若执行边界薄弱，生成的命令可将模型输出直接转化为系统效果。	边界校验与上下文隔离、执行隔离与行动约束、人工授权与可逆性。
AML.T0103	Deploy AI Agent	对手可能在企业环境中植入或改造代理，使其成为自主执行组件。	最小权限与分段隔离、身份、凭据与委托治理、变更控制与重新验证。
AML.T0104	Publish Poisoned AI Agent Tool	工具依赖、插件、Hook、脚本和描述符可能在上游被污染，而在下游被错误信任。	来源、完整性与依赖保证、第三方与集中度风险管理、独立测试与对抗性评估。
AML.T0105	Escape to Host	对具备代码执行能力的代理、沙箱和执行代理而言，逃逸到宿主机仍是关键边界失效。	执行隔离与行动约束、最小权限与分段隔离、运行时护栏、检测与响应。
AML.T0106	Exploitation for Credential Access	AI 环境中的凭据获取可能暴露模型服务路径、客户数据、欺诈工具和控制系统。	身份、凭据与委托治理、最小权限与分段隔离、日志、证据与可调查性。
AML.T0109	AI Supply Chain Rug Pull	供应链撤回或恶意变更可能引发突发的完整性、可用性或控制失效。	第三方与集中度风险管理、变更控制与重新验证、韧性、回退与安全降级。
AML.T0110	AI Agent Tool Poisoning	工具投毒与依赖工具元数据、工具输出或执行路径的代理式系统直接相关。	来源、完整性与依赖保证、边界校验与上下文隔离、运行时护栏、检测与响应。
AML.T0112	Machine Compromise	AI 受损可进一步演变为传统主机或工作负载受损，并带来更广泛运营后果。	运行时护栏、检测与响应、韧性、回退与安全降级、日志、证据与可调查性。

E.4 优先缓解控制参考

下表保留了对企业实施与审查最有用的缓解措施，优先选择能够清晰映射到本指引控制语言、且会实质影响应用安全、代理安全、可观测性、身份、供应链或发布控制的措施。

缓解编号	缓解名称	在此处的重要性	指引控制对应关系
AML.M0000	Limit Public Release of Information	降低公开技术披露对侦察和代理模型准备的价值。	数据最小化与保密保护、边界校验与上下文隔离。
AML.M0001	Limit Model Artifact Release	限制权重、架构细节及其他对复制或定向攻击设计有价值的工件暴露。	来源、完整性与依赖保证、第三方与集中度风险管理。
AML.M0004	Restrict Number of AI Model Queries	有助于约束抽取、滥用、侦察和无界消耗模式。	运行时护栏、检测与响应、韧性、回退与安全降级。
AML.M0005	Control Access to AI Models and Data at Rest	仍是保护模型工件、数据集及邻接敏感存储的基础措施。	最小权限与分段隔离、身份、凭据与委托治理。
AML.M0013	Code Signing	有助于检测供应链中模型、工具或发布工件的不安全替换。	来源、完整性与依赖保证、变更控制与重新验证。
AML.M0014	Verify AI Artifacts	支持在使用前对模型、适配器、代理及相关工件进行受控引入。	来源、完整性与依赖保证、独立测试与对抗性评估。
AML.M0015	Adversarial Input Detection	有助于在运行时发现提示攻击、恶意载荷和异常输入。	边界校验与上下文隔离、运行时护栏、检测与响应。
AML.M0019	Control Access to AI Models and Data in Production	连接部署期策略、访问治理和运行遏制。	最小权限与分段隔离、日志、证据与可调查性。
AML.M0023	AI Bill of Materials	增强模型、工具、插件、连接器及相关依赖的供应链可见性。	来源、完整性与依赖保证、第三方与集中度风险管理。
AML.M0024	AI Telemetry Logging	直接支撑企业级可观测性、调查和事件后学习。	日志、证据与可调查性、运行时护栏、检测与响应。
AML.M0026	Privileged AI Agent Permissions Configuration	凡是代理持有高权限或可影响关键系统时，该措施都具有直接相关性。	最小权限与分段隔离、身份、凭据与委托治理。
AML.M0028	AI Agent Tools Permissions Configuration	有助于约束使用工具的代理、连接器、脚本和执行代理。	执行隔离与行动约束、最小权限与分段隔离。
AML.M0029	Human In-the-Loop for AI Agent Actions	强化代理或高影响工作流对重大行动的审批关口。	人工授权与可逆性、信任校准与决策呈现。
AML.M0030	Restrict AI Agent Tool Invocation on Untrusted Data	有助于防范代理式工作流中的提示注入和工具滥用。	边界校验与上下文隔离、运行时护栏、检测与响应。
AML.M0031	Memory Hardening	与持久记忆、上下文投毒和代理状态完整性直接相关。	边界校验与上下文隔离、变更控制与重新验证。
AML.M0034	Deepfake Detection	对身份滥用、社会工程和金融行业欺诈场景尤其相关。	独立测试与对抗性评估、运行时护栏、检测与响应。